

NGUYỄN KHANH VĂN

GIÁO TRÌNH
CƠ SỞ AN TOÀN THÔNG TIN

(Xuất bản lần thứ hai, có sửa chữa)

NHÀ XUẤT BẢN BÁCH KHOA HÀ NỘI

Bản quyền thuộc về trường Đại học Bách Khoa Hà Nội.

Mọi hình thức xuất bản, sao chép mà không có sự cho phép bằng văn bản của trường là vi phạm pháp luật.

Mã số: 205 – 2015/CXB/55 – 02/BKHN

Biên mục trên xuất bản phẩm của Thư viện Quốc gia Việt Nam

Nguyễn Khanh Văn

Cơ sở an toàn thông tin / Nguyễn Khanh Văn. - H. : Bách khoa Hà Nội, 2015.
- 216tr. ; 24cm

Th mục: tr. 214-215

ISBN 978-604-938-249-9

1. An toàn thông tin 2. Giáo trình
005.8 - dc23

BKG0020p-CIP

LỜI MỞ ĐẦU

Với sự phát triển bùng nổ hiện nay của công nghệ thông tin và ứng dụng trong đời sống, đặc biệt là các hệ thống mạng truyền tin và các hệ thống thương mại điện tử, các vấn đề về an toàn và bảo mật trở nên có tầm quan trọng thời sự. Trước kia, mục đích chủ đạo trong thiết kế một hệ thống thông tin là làm sao cho hệ thống được đảm bảo các chức năng làm việc, chạy tốt, ít lỗi và dễ phát triển, dễ kết nối với các hệ thống khác. Riêng các vấn đề này cũng đủ làm đau đầu các nhà thiết kế, vì thế an toàn bảo mật là mối quan tâm thứ yếu (mặc dù vẫn được nêu cao trong giấy tờ). Tuy nhiên, với xu hướng xích lại gần nhau của cả thế giới, công việc của mỗi cơ sở, mỗi doanh nghiệp không còn là việc “bếp núc của từng nhà” nữa. Các mạng truyền thông diện rộng đã cho mỗi cơ quan tổ chức mở cửa kết nối, giao tiếp với các cơ sở bạn bè khắp nơi nhưng cũng vì thế mà tạo cơ hội cho các hàng xóm “thù địch” thường xuyên tìm cách “dòm ngó” và “quấy phá”. Câu hỏi ngược bây giờ là liệu một hệ thống thông tin có đáng được đánh giá cao hay không nếu nó không được bảo vệ để chống lại đủ mọi loại tấn công và xâm nhập của kẻ cả kẻ địch bên ngoài lẫn gián điệp bên trong? Với nhiều hệ thống quan trọng, thực sự bài toán an toàn bảo mật được đặt lên hàng đầu với chi phí lên tới 60% chi phí tổng thể. Qua đó chúng ta thấy một nhiệm vụ thường xuyên của các kỹ sư tin học là nắm vững và trau dồi các kiến thức về an toàn bảo mật thông tin, nhằm hướng tới thiết kế và xây dựng các phần mềm tốt hơn, an toàn hơn.

Giáo trình Cơ sở An toàn thông tin được biên soạn cho đối tượng là sinh viên các năm cuối và học viên cao học của các trường đại học kỹ thuật. Tác giả hy vọng rằng giáo trình sẽ cung cấp một cách tiếp cận tổng thể các khái niệm cơ bản về các vấn đề xung quanh bảo vệ các hệ thống tin học (HTTH), đồng thời giới thiệu những kiến thức về lĩnh vực an toàn và bảo mật máy tính (computer security) ở mức độ tiệm cận chuyên sâu. Qua đó, người đọc có thể hình dung cụ thể về các chủ đề nghiên cứu chính trong lĩnh vực này.

Trong khuôn khổ của một giáo trình cơ sở, tác giả sẽ tập trung vào diễn giải cặn kẽ những kiến thức cơ bản và then chốt, với mức ưu tiên cao hơn so với các kỹ thuật chuyên sâu hơn và các phần mở rộng. Tác giả đặc biệt chú ý tới việc trình bày kỹ lưỡng các kiến thức cơ bản của lý thuyết mật mã, một lĩnh vực khó đối với các học viên ngành Công nghệ thông tin (CNTT), thông qua một tiếp cận mang tính truyền thống, nhưng vẫn có tính hiện đại thể hiện qua việc liên tục kết nối với các bài toán thực tế hiện nay. Những vấn đề được chọn trình bày kỹ lưỡng đều thuộc về cơ sở của lĩnh vực,

những phần mang tính nâng cao thường được điểm qua hoặc đưa ra như những câu hỏi và bài tập mở rộng.

Về lý thuyết mật mã, một nền tảng căn bản của an toàn thông tin (ATTT), các khái niệm cơ bản sẽ được đề cập bao gồm: hệ mã hóa đối xứng, mã hóa phi đối xứng (khóa công khai), hàm băm, chữ ký điện tử... Các mô hình phát triển hơn sẽ được giới thiệu là vấn đề trao chuyển khóa và giao thức mật mã (cryptographic protocol). Bên cạnh đó, các nền tảng cơ sở khác của ATTT như xác thực (authentication), điều khiển quyền truy nhập (access control), các mô hình an toàn mạng, mã độc và tấn công lợi dụng cũng là các chủ đề trọng tâm.

Giáo trình này là kết quả của quá trình tổng hợp các kiến thức và kinh nghiệm giảng dạy nhiều năm của tác giả tại Đại học Bách Khoa Hà Nội về chủ đề An toàn thông tin (bắt đầu từ năm 1998). Đặc biệt, do thời gian gấp rút nên nội dung và một số phần trình bày là tài liệu giảng dạy đã viết từ những năm 1998 – 2000 chưa được hoàn toàn cập nhật và cô đọng, thiếu các diễn giải chi tiết, nhiều vấn đề chỉ nêu mà chưa minh họa. Đây là lần xuất bản đầu tiên, nên mặc dù tác giả đã rất cố gắng song ***Giáo trình Cơ sở an toàn thông tin*** sẽ không tránh khỏi những khiếm khuyết nhất định. Tác giả rất mong nhận được những ý kiến đóng góp, trao đổi của các nhà khoa học, đồng nghiệp và các độc giả để cuốn sách ngày càng được hoàn thiện hơn trong những lần xuất bản tiếp theo và trở nên hữu ích cho bạn đọc.

Mọi ý kiến đóng góp xin gửi về địa chỉ:

TS. Nguyễn Khanh Văn

P. 601 – nhà B1, Bộ môn Công nghệ Phần mềm

Viện Công nghệ Thông tin & Truyền thông

Đại học Bách Khoa Hà Nội, số 01 Đại Cồ Việt, Hà Nội, Việt Nam

Email: vannk@soict.hust.edu.vn; van.nguyenkhanh@hust.edu.vn

Xin cảm ơn bạn đọc!

TÁC GIẢ

MỤC LỤC

LỜI MỞ ĐẦU.....	3
CHƯƠNG MỞ ĐẦU. TỔNG QUAN VỀ AN TOÀN THÔNG TIN VA GIỚI THIỆU GIAO TRÌNH	11
A. Một tiếp cận khái quát & tổng thể trong xây dựng một giải pháp an toàn thông tin.....	12
A.1. Mục tiêu và nguyên tắc chung của ATBM (an toàn & bảo mật – security) ...	13
A.2. Phân loại các đe dọa.....	14
A.3. Chính sách và cơ chế	15
A.4. Kiểm tra và kiểm soát	16
A.5. Xung quanh chủ đề điều hành (operational issues)	17
A.6. Vòng đời an toàn thông tin.....	18
B. Nền tảng cơ sở của người kỹ sư an toàn thông tin.....	19
B.1. Quan điểm xây dựng và cấu trúc chung của giáo trình	20
B.2. Các nội dung cơ bản của giáo trình.....	21
PHẦN I. CƠ SỞ LÝ THUYẾT MẬT MÃ VÀ ỨNG DỤNG	24
Chương 1. CÁC KHÁI NIỆM CƠ SỞ & HỆ MÃ CỔ ĐIỂN.....	24
1.1. Các khái niệm cơ sở.....	24
1.1.1. Những kỹ nguyên quan trọng trong ngành mật mã.....	25
1.1.2. Mô hình truyền tin mật cơ bản.....	26
1.1.3. Hệ thống mật mã đối xứng (Symmetric Key Cryptosystem – SKC).....	27
1.1.4. Hệ thống mật mã khóa công khai hay phi đối xứng (Public Key Cryptosystem – PKC).....	28
1.1.5. Đánh giá tính bảo mật của các hệ mật mã.....	28
1.2. Một số hệ mật mã cổ điển.....	31
1.2.1. Mật mã một bảng thế (Monoalphabetic cipher)	31
1.2.2. Phân tích giải mã theo phương pháp thống kê (Statistical cryptanalysis).....	34
1.2.3. Phương pháp bằng phẳng hóa đồ thị tần suất	37
1.2.4. Vigenere cipher	38
1.2.5. One-time-pad (Vernam cipher)	41
★ 1.3. Lý thuyết về sự bí mật tuyệt đối (Shannon).....	41
1.3.1. Bí mật tuyệt đối là gì?.....	41
1.3.2. Khái niệm bí mật tuyệt đối.....	44
1.3.3. Đánh giá mức độ bảo mật của một cipher.....	45
Câu hỏi và bài tập	47

Chương 2. MẬT MÃ KHỐI VÀ MẬT MÃ KHÓA ĐỐI XỨNG.....	49
2.1. Khái niệm và nguyên lý thiết kế cơ sở.....	49
2.2. Chuẩn mật mã DES	52
2.2.1. Lịch sử của DES	52
2.2.2. Thuật toán và lưu đồ hoạt động của DES.....	52
★ 2.2.3 Các điểm yếu của DES.....	57
2.2.4. Tấn công bằng phương pháp vét cạn (hay là brute-force attack).....	57
★ 2.2.5. Tăng kích thước khóa của DES	58
★ 2.2.6. Các dạng tấn công khác	59
2.3. Các hệ mật mã khối khác	59
2.3.1. Các mật mã khối khác (cho đến năm 1999).....	59
2.3.2. Mật mã AES.....	59
2.4. Các chế độ sử dụng mã khối	60
2.4.1. Chế độ bảng tra mã điện tử (Electronic code book – ECB).....	60
2.4.2. Chế độ mã móc xích (Cipher Block Chaining – CBC).....	61
2.4.3. Chế độ mã phản hồi k-bit (k-bit Cipher Feedback Mode – CFB).....	62
2.4.4. Chế độ mật mã kết quả phản hồi (Output Feedback Mode – OFB).....	63
2.4.5. Chế độ mật mã con đếm (Counter mode – CTR).....	63
Câu hỏi và bài tập	65

Chương 3. HỆ THỐNG MẬT MÃ KHÓA CÔNG KHAI.... ERROR! BOOKMARK NOT DEFINED.

3.1. Giới thiệu.....	Error! Bookmark not defined.
3.2. Merkle–Hellman Trapdoor Knapsack	
(Cửa bẫy dựa trên bài toán đóng thùng).....	Error! Bookmark not defined.
3.2.1. Bài toán đóng thùng.....	Error! Bookmark not defined.
3.2.2. Thuật toán Merkle–Hellman	Error! Bookmark not defined.
3.2.3. Tấn công vũ lực (Brute Force Attack).....	Error! Bookmark not defined.
3.2.4. Sự đổ vỡ của giải pháp dùng Knapsack (1982 – 1984).....	Error! Bookmark not defined.
3.2.5. Thuật toán tìm giá trị nghịch đảo theo module đồng dư	Error! Bookmark not defined.
3.3. Hệ thống khóa công khai RSA	Error! Bookmark not defined.
3.3.1. Ý tưởng (Motivation)	Error! Bookmark not defined.
3.3.2. Thuật toán RSA	Error! Bookmark not defined.
3.3.3. Một số ứng dụng cơ bản (của các hệ thống mật mã khóa công khai nói chung).....	Error! Bookmark not defined.
★ 3.3.4. Một số vấn đề xung quanh thuật toán RSA ...	Error! Bookmark not defined.

★ 3.3.5. Điểm yếu của thuật toán RSA	Error! Bookmark not defined.
★ 3.3.6. Đánh giá về an toàn của thuật toán RSA	Error! Bookmark not defined.
★ 3.4. Một số hệ PKC khác.....	Error! Bookmark not defined.
3.4.1. Hệ Rabin.....	Error! Bookmark not defined.
3.4.2. Hệ El-Gamal.....	Error! Bookmark not defined.
Câu hỏi và bài tập	Error! Bookmark not defined.
Chương 4. CHỮ KÝ ĐIỆN TỬ VÀ HÀM BẮM	ERROR! BOOKMARK NOT DEFINED.
4.1. Các khái niệm và nguyên lý thiết kế cơ sở.....	Error! Bookmark not defined.
4.1.1. Sơ đồ chữ ký cơ bản	Error! Bookmark not defined.
4.1.2. Các ứng dụng của chữ ký điện tử	Error! Bookmark not defined.
4.1.3. Nhược điểm của hệ chữ ký cơ sở.....	Error! Bookmark not defined.
4.2. Hàm băm và ứng dụng chữ ký điện tử	Error! Bookmark not defined.
4.2.1. Độ dài	Error! Bookmark not defined.
4.2.2. Birthday attack	Error! Bookmark not defined.
4.3. Các kỹ thuật làm hàm băm.....	Error! Bookmark not defined.
4.3.1. Các hàm băm chế từ hệ SKC	Error! Bookmark not defined.
4.3.2. Các hàm băm dựa trên các phép toán số học đồng dư	Error! Bookmark not defined.
4.3.3. Các hàm băm được chế tạo đặc biệt	Error! Bookmark not defined.
★ 4.4. Các hệ chữ ký khác RSA.....	Error! Bookmark not defined.
★ 4.5. Các hệ DS đặc biệt	Error! Bookmark not defined.
4.5.1. Chữ ký mù (Blind signature).....	Error! Bookmark not defined.
4.5.2. Group signature.....	Error! Bookmark not defined.
4.5.3. Undeniable signature	Error! Bookmark not defined.
4.5.4. Multisignature (đồng ký).....	Error! Bookmark not defined.
4.5.5. Proxy signature (chữ ký ủy nhiệm)	Error! Bookmark not defined.
Câu hỏi và bài tập mở rộng.....	Error! Bookmark not defined.
Chương 5. QUẢN LÝ KHÓA	ERROR! BOOKMARK NOT DEFINED.
5.1. Xác lập và trao chuyển khóa bí mật trong SKC	Error! Bookmark not defined.
5.1.1. Khóa phiên	Error! Bookmark not defined.
5.1.2. Trao chuyển xác lập khóa đối xứng sử dụng người trung gian tin cậy	Error! Bookmark not defined.
5.1.3. Sự cố mất khóa phiên cũ và giải pháp phòng vệ	Error! Bookmark not defined.
★ 5.1.4. Giao thức Kerberos	Error! Bookmark not defined.

★ 5.1.5. Vấn đề sinh khóa.....	Error! Bookmark not defined.
5.2. Dùng PKC để trao chuyển khóa bí mật.....	Error! Bookmark not defined.
5.2.1. Phương án thứ nhất.....	Error! Bookmark not defined.
5.2.2. Phương án thứ hai: phương án bắt tay ba bước Needham–Schroeder ..	Error!
Bookmark not defined.	

5.3. Hạ tầng khóa mật mã công khai (Public Key Infrastructure)Error! Bookmark not defined.

5.3.1. Khuyến nghị về một cơ chế chứng thực của ISO
(ISO Authentication Framework – X.509)....**Error! Bookmark not defined.**

5.3.2. Vấn đề thẩm định chứng chỉ khóa công khai**Error! Bookmark not defined.**

★**5.4. Giao thức thống nhất khóa Diffie–Hellman** Error! Bookmark not defined.

Câu hỏi và bài tập Error! Bookmark not defined.

PHẦN II. KIỂM SOÁT HỆ THỐNG.....**Error! Bookmark not defined.**

Chương 6. XÁC THỰC**Error! Bookmark not defined.**

6.1. Khái niệm cơ bản..... Error! Bookmark not defined.

6.2. Sử dụng mật khẩu Error! Bookmark not defined.

6.2.1. Tấn công mật khẩu.....**Error! Bookmark not defined.**

6.2.2. Các cơ chế phòng vệ.....**Error! Bookmark not defined.**

6.3. Thách thức – Đáp ứng Error! Bookmark not defined.

6.4. Xác thực qua sinh trắc Error! Bookmark not defined.

6.5. Xác thực qua địa điểm Error! Bookmark not defined.

6.6. Phối hợp nhiều phương pháp Error! Bookmark not defined.

★**6.7. Tấn công mật khẩu trên đường truyền**..... Error! Bookmark not defined.

Câu hỏi và bài tập Error! Bookmark not defined.

Chương 7. ĐIỀU KHIỂN TRUY NHẬP....**Error! Bookmark not defined.**

7.1. Khái niệm cơ bản..... Error! Bookmark not defined.

7.2. Ma trận điều khiển truy nhập Error! Bookmark not defined.

7.2.1. Khái niệm chung.....**Error! Bookmark not defined.**

7.2.2. Danh sách quyền truy nhập (Access Control List: ACL) ..**Error! Bookmark not defined.**

7.2.3. Danh sách năng lực (capability list).....**Error! Bookmark not defined.**

7.3. Mô hình Harrison–Ruzzo–Ullman và Điều khiển truy nhập tùy nghi.... Error! Bookmark not defined.

7.3.1. Mô hình Harrison–Ruzzo–Ullman (HRU) ...**Error! Bookmark not defined.**

7.3.2. Điều khiển truy nhập tùy nghi (Discretionary Access Control – DAC)

.....**Error! Bookmark not defined.**

7.4. Điều khiển truy nhập cưỡng chế (Mandatory Access Control – MAC).. Error! Bookmark not defined.

7.5. Điều khiển truy nhập dựa vai trò (Role–Based Access Control – RBAC)

Error! Bookmark not defined.

7.5.1. Mô hình cơ sở RBAC₀**Error! Bookmark not defined.**

7.5.2. Mô hình cơ sở RBAC₁**Error! Bookmark not defined.**

★ **7.6. Case Study: Điều khiển truy nhập trong hệ điều hành Unix** Error! Bookmark not defined.

7.6.1. Tổ chức của các file dữ liệu và dữ liệu điều khiển **Error! Bookmark not defined.**

7.6.2. Chủ thể, sự đại diện và đặc quyền **Error! Bookmark not defined.**

Câu hỏi và bài tập Error! Bookmark not defined.

PHẦN III. KHẢO SÁT MỘT SỐ LĨNH VỰC CỤ THỂ TRONG

THỰC TẾ.....**ERROR! BOOKMARK NOT DEFINED.**

Chương 8. AN TOÀN TRÊN INTERNET.**ERROR! BOOKMARK NOT DEFINED.**

8.1. Tổng quan Error! Bookmark not defined.

8.2. An toàn với giao thức mạng Error! Bookmark not defined.

8.2.1. Khái niệm chung **Error! Bookmark not defined.**

8.2.2. Tầng giao vận và tấn công DOS bằng dòng thác SYN **Error! Bookmark not defined.**

8.2.3. Một số giải pháp cho tấn công DOS trên TCP **Error! Bookmark not defined.**

8.2.4. Tấn công vào điều khiển tắc nghẽn TCP **Error! Bookmark not defined.**

8.3. Bảo mật truyền tin tầng IP: giải pháp IPSEC Error! Bookmark not defined.

8.3.1. Mối liên kết an toàn (security association) **Error! Bookmark not defined.**

8.3.2. Giao thức AH (Authentication Header) **Error! Bookmark not defined.**

8.3.3. Giao thức đóng gói an toàn ESP **Error! Bookmark not defined.**

8.4. Bảo mật tầng TCP: họ giao thức SSL/TLS Error! Bookmark not defined.

8.4.1. Kiến trúc và các khái niệm cơ bản **Error! Bookmark not defined.**

8.4.2. Giao thức SSL Record protocol **Error! Bookmark not defined.**

8.4.3. Giao thức bắt tay Handshake protocol **Error! Bookmark not defined.**

8.5. Phòng vệ cho hệ thống kết nối mạng Error! Bookmark not defined.

8.5.1. Bức tường lửa **Error! Bookmark not defined.**

8.5.2. Mạng riêng ảo **Error! Bookmark not defined.**

8.5.3. Hệ thống dò tìm đột nhập **Error! Bookmark not defined.**

Câu hỏi và bài tập Error! Bookmark not defined.

Chương 9. MÃ ĐỘC VÀ AN TOÀN PHẦN MỀM......**ERROR! BOOKMARK NOT DEFINED.**

9.1. Khái niệm mã độc Error! Bookmark not defined.

9.1.1. Backdoor **Error! Bookmark not defined.**

9.1.2. Bom logic **Error! Bookmark not defined.**

9.1.3. Ngựa Trojan **Error! Bookmark not defined.**

9.2. Virus máy tính Error! Bookmark not defined.

9.2.1. Định nghĩa, cấu trúc và cách thức hoạt động	Error! Bookmark not defined.
9.2.2. Các loại virus.....	Error! Bookmark not defined.
9.3. Sâu máy tính (worm)	Error! Bookmark not defined.
9.3.1. Định nghĩa, cấu trúc và cách thức hoạt động	Error! Bookmark not defined.
9.3.2. Sâu Morris	Error! Bookmark not defined.
9.4. Lỗi tràn bộ đệm (Buffer overflow).....	Error! Bookmark not defined.
9.5. Tổng quan về an toàn ứng dụng Web	Error! Bookmark not defined.
9.5.1. Một số nguy cơ phổ biến đối với ứng dụng Web	Error! Bookmark not defined.
9.5.2. Một số quan sát đối với đảm bảo an toàn trong cộng đồng xây dựng Web tại Việt Nam trong giai đoạn 2006 – 2010	Error! Bookmark not defined.
★9.6. Giới thiệu tấn công Cross-Site Scripting (XSS) ..	Error! Bookmark not defined.
9.6.1. Khái niệm	Error! Bookmark not defined.
9.6.2. Phân loại	Error! Bookmark not defined.
★9.7. Giới thiệu tấn công SQL Injection	Error! Bookmark not defined.
9.7.1. Khái niệm	Error! Bookmark not defined.
9.7.2. Stored procedure	Error! Bookmark not defined.
9.7.3. Khai thác thông tin dựa vào các thông điệp lỗi.....	Error! Bookmark not defined.
Câu hỏi và bài tập	Error! Bookmark not defined.

PHẦN IV. PHẦN ĐỌC THÊM.....ERROR! BOOKMARK NOT DEFINED.

★ CHƯƠNG 10. GIAO THỨC MẬT MÃ VÀ ỨNG DỤNG ERROR! BOOKMARK NOT DEFINED.

10.1. Tổng quan.....	Error! Bookmark not defined.
10.1.1. Định nghĩa và thuộc tính	Error! Bookmark not defined.
10.1.2. Mục đích của các protocols.....	Error! Bookmark not defined.
10.1.3. Các bên tham gia vào protocol (the Players)	Error! Bookmark not defined.
10.2. Phân loại protocols	Error! Bookmark not defined.
10.2.1. Protocols có người trọng tài	Error! Bookmark not defined.
10.2.2. Protocols có người phân xử.	Error! Bookmark not defined.
10.2.3. Protocol tự xử (Self-enforcing protocol)	Error! Bookmark not defined.
10.3. Các dạng tấn công đối với protocols.....	Error! Bookmark not defined.
10.4. Nhìn lại một số giao thức mật mã đã học	Error! Bookmark not defined.
10.5. Một số giao thức căn bản và nâng cao	Error! Bookmark not defined.

10.5.1. Trao đổi tin mật không cần trao đổi khóa (Shamir 3-pass protocol) ..	Error!
Bookmark not defined.	
10.5.2. Giao thức thống nhất khóa Diffie–Hellman	Error! Bookmark not defined.
10.5.3. Zero–knowledge protocols.....	Error! Bookmark not defined.
10.6. Ứng dụng: giới thiệu về thanh toán điện tử	Error! Bookmark not defined.
10.6.1. Tổng quan về thanh toán điện tử	Error! Bookmark not defined.
10.6.2. Mô hình trả sau (Pay–now/Pay–later)	Error! Bookmark not defined.
10.6.3. Mô hình trả trước	Error! Bookmark not defined.
10.6.4. Sơ lược về mô hình tiền mặt điện tử (Electronic Cash) ...	Error! Bookmark not defined.
not defined.	
Câu hỏi và bài tập	Error! Bookmark not defined.
TÀI LIỆU THAM KHẢO	Error! Bookmark not defined.

Chương Mở đầu

TỔNG QUAN VỀ AN TOÀN THÔNG TIN VÀ GIỚI THIỆU GIÁO TRÌNH

An toàn thông tin (ATTT) đang phát triển nhanh chóng, trở thành một chuyên ngành lớn của *Khoa học Máy tính* hay *Công nghệ Thông tin* nói chung. Đào tạo ở mức chuyên gia về an toàn thông tin trong chương trình đại học có lẽ đòi hỏi phải có một nhóm các môn học riêng, hay một chương trình chuyên ngành riêng; ở nước ta cũng đã có nơi có trường đại học tổ chức bộ môn An toàn thông tin. Trong một chương trình đại học chung cho Công nghệ Thông tin, kiến thức nền tảng về An toàn thông tin đã trở thành một trong những cơ sở căn bản không thể thiếu được. Tuy nhiên có những khó khăn nhất định trong việc thiết kế một môn học cơ sở bao hàm chung các kiến thức cần thiết về ATTT.

Các vấn đề cụ thể của ATTT như an ninh mạng, an toàn phần mềm nói chung hay ứng dụng Web,... đã trở thành những vấn đề nóng, thường ngày ở các công ty tin học. Vì vậy, các công ty yêu cầu mỗi một kỹ sư tin học tốt nghiệp loại khá phải nắm vững được cách tiếp cận và giải quyết sao cho phù hợp thực tế và hiệu quả. Đặc biệt là một kỹ sư chuyên gia cần nắm được lĩnh vực với cách nhìn phân tích đầy đủ theo tiếp

cận trên – xuống (top – down). Điều này đáng tiếc là kiến thức cơ sở bậc đại học không thể giúp ngay được.

Theo truyền thống của học thuật nói chung và giảng dạy đại học nói riêng, các sách giáo khoa và chương trình môn học thường được xây dựng theo tiếp cận dưới – lên (bottom – up). Trong đó, các kiến thức cơ sở thuần túy học thuật thường được giới thiệu trước; chỉ khi các kiến thức cơ sở (phần lớn mang tính hàn lâm, khoa học) đã được giới thiệu bài bản, các chủ đề mang tính ứng dụng, giải quyết các bài toán nảy sinh trực tiếp từ thực tế mới có thể được trình bày, nhằm giải quyết thấu đáo và cung cấp cơ sở lập luận khoa học chặt chẽ cho các giải pháp. Tuy nhiên, do thời lượng chương trình là khá ngắn so với khối lượng kiến thức cơ sở (mang tính hàn lâm) yêu cầu bắt buộc, phần chủ đề nâng cao, mang tính hướng thực tế, ứng dụng thường trở nên eo hẹp, lép vế, khó đem lại sức sống thực tế như mong muốn.

Qua quá trình giảng dạy tương đối lâu năm, chúng tôi nhận thức rõ những bất cập trên. Thậm chí với xu hướng chung là sự phát triển nhanh của lĩnh vực và tính nóng của nó, khó có một tiếp cận hợp lý, đẹp đẽ để thỏa mãn cả hai xu hướng yêu cầu này. Nhiệm vụ của chương mở đầu chính là để nhằm phần nào giải quyết bất cập này, đưa ra một bức tranh chung tương đối phù hợp vừa cho thấy sự cần thiết phải nắm được nhu cầu thực tế về ATTT (tiếp cận trên – xuống) vừa giới thiệu khái quát về phương thức hàn lâm truyền thống mà giáo trình này đi theo (tiếp cận dưới – lên).

Chương mở đầu này được thể hiện trong hai phần với mục đích ứng tạo sự nối ghép nói trên. Trong phần thứ nhất, chúng ta làm quen với các khái niệm khái quát chung để có một cái nhìn tổng thể về lĩnh vực. Để có một cái nhìn bao quát, ta sẽ thử thâm nhập vào lĩnh vực *trong vai trò như một* chuyên gia cấp cao, một kiến trúc sư an toàn thông tin, người có trách nhiệm phải xây dựng một giải pháp an toàn tổng thể cho một hệ thống tin học. Với cách tiếp cận này, người đọc sẽ được trang bị một tầm nhìn bao quát, dần phát triển khả năng đọc các tình huống thực tế và trên cơ sở đó có thể chủ động liên hệ các kiến thức học thuật và kỹ thuật cụ thể ở các chương sau vào các bài toán thực tế. Đây chính là cách nhìn theo tiếp cận trên – xuống yêu cầu khi làm thực tế đã nói ở trên.

Phần sau của chương sẽ mô tả một bức tranh tổng quan về nền tảng học vấn cơ sở mà một sinh viên tốt nghiệp đại học kỹ thuật cần trang bị về an toàn thông tin. Chúng tôi sẽ giới thiệu với bạn đọc về các nền tảng học thuật cơ sở của an toàn thông tin ở dạng khái quát nhất. Bên cạnh đó, chúng tôi thể hiện quan điểm xây dựng giáo trình và giới thiệu các nội dung trình bày chính của giáo trình. Qua đó chúng tôi sẽ có cơ hội chia sẻ những lý do về cách xây dựng và tầm quan trọng của các khối kiến thức được chọn lựa để đưa vào giáo trình cơ sở này.

Theo quan điểm riêng của chúng tôi, sự có mặt của chương Mở đầu này sẽ đem lại lợi ích nhiều nhất cho các bạn đọc tự học, giúp các bạn mặc dù thiếu tiếp xúc với môi trường chuyên môn, thầy giáo nhưng vẫn có thể tự tìm tòi được những mối liên hệ của những kiến thức cơ sở hàn lâm với các bài toán cụ thể thực tế.

A. MỘT TIẾP CẬN KHÁI QUÁT & TỔNG THỂ TRONG XÂY DỰNG MỘT GIẢI PHÁP AN TOÀN THÔNG TIN

Chúng ta hãy tìm hiểu khái niệm "bảo vệ hệ thống". Ở đây, ta có thể đặt ra một số câu hỏi như: "Hệ thống là gì?", "Cái gì trong hệ thống cần phải bảo vệ?", "Bảo vệ khỏi cái gì?" và "Bảo vệ bằng cách nào?". Có thể trả lời tóm tắt như sau. Ở đây đối tượng hệ thống chủ yếu ta quan tâm là các hệ thống thông tin (HTTT), với các *tài sản* (assets) cần phải bảo vệ để chống lại những mối *đe dọa* (threats), thông qua các biện pháp ngăn chặn (BPNC), tức là các công cụ điều khiển (control). Hiệu quả của các BPNC được đánh giá thông qua chi phí (cost) của chúng và kết quả thu được. Chúng ta hãy điểm qua ý nghĩa cụ thể của các khái niệm này.

Tài sản: Hệ thống máy tính là một tập hợp gồm các thành phần của phần cứng, phần mềm và dữ liệu. Mỗi thành tố là một tài sản cần bảo vệ. Như vậy tài sản ở đây có thể là thiết bị, chương trình cài đặt và các dữ liệu làm việc được tích lũy qua thời gian.

Mối đe dọa: là khả năng có thể bị tấn công, bị khai thác vào những điểm yếu của hệ thống. Có ba hình thức chính như sau:

- **Phá hoại:** trong đó một tài sản nào đó bị làm mất giá trị. Ví dụ như: phá hỏng một thiết bị phần cứng hay xóa một chương trình cài đặt.

- **Can thiệp** (interception): tài sản bị truy nhập trái phép bởi những người không có thẩm quyền. Ví dụ: nghe trộm trên mạng (wiretapping network), sao chép trái phép. Những tấn công này thông thường rất khó phát hiện.

- **Sửa đổi:** các tài sản bị sửa đổi, đánh tráo trái phép. Ví dụ: sửa đổi dữ liệu trong các CSDL hoặc đang trên đường truyền qua mạng.

Các thiệt hại gây ra bởi các tấn công đối với phần mềm và dữ liệu có thể dễ dàng phát hiện thông qua các dấu hiệu như việc chương trình treo khi chạy hoặc dữ liệu hỏng. Tuy nhiên cũng có khi rất khó phát hiện khi đối phương cố tình không để lại dấu vết (trường hợp các virus "mìn hẹn giờ"). Những loại này có thể phát hiện được nhờ những hiệu ứng hay bằng các chương trình kiểm tra thường xuyên.

Vậy một chuyên gia chủ trì xây dựng một giải pháp ATTT cho một hệ thống tin học của một doanh nghiệp cụ thể, sẽ cần phải thực hiện các bước công việc như thế nào? Trước nhất, chuyên gia này cần phân tích khảo sát và nắm vững các mục tiêu cụ thể của bài toán an toàn và bảo mật (ATBM) cho hệ thống của mình.

A.1. Mục tiêu và nguyên tắc chung của ATBM (an toàn & bảo mật – security)

Có ba mục tiêu cơ bản của an toàn và bảo mật (ATBM) các hệ thống tin học:

1. **Đảm bảo tính bí mật (Confidentiality):** đảm bảo tài sản không thể bị truy nhập trái phép bởi những người không có thẩm quyền.

2. **Đảm bảo tính nguyên vẹn (Integrity):** đảm bảo tài sản không thể bị sửa đổi, bị làm giả bởi những người không có thẩm quyền.

3. Tính khả dụng, hay sẵn dùng (Availability): đảm bảo tài sản là sẵn sàng để đáp ứng sử dụng cho người có thẩm quyền

Một giải pháp ATBM xây dựng cần nhằm đạt được cả ba mục tiêu cơ bản trên một cách hài hòa. Cần phân biệt sự khác biệt giữa tính mật và tính nguyên vẹn. Có những tấn công phá vỡ tính nguyên vẹn nhưng không phá vỡ tính mật và ngược lại. Nếu ta gửi thông tin trên đường truyền mạng công cộng mà có kẻ bên ngoài xem lén được (qua việc tóm và đọc các gói tin gửi qua các nút trung gian thuộc địa phận ta không kiểm soát được), đó là tính mật đã bị vi phạm. Nếu kẻ gian can thiệp sửa đổi, dù chỉ 1 bit trên những gói tin này (mặc dù chúng có thể không đọc hiểu được) và người nhận tin không phát hiện ra sự thay đổi đó, thì tính nguyên vẹn đã bị xâm phạm. Mặc dù ta không thể ngăn chặn việc sửa đổi tùy tiện khi các gói tin đi qua các điểm trung gian không thuộc quyền kiểm soát, nếu ta phát hiện được (ở phía máy nhận) sự thay đổi trái phép, thì ta có thể yêu cầu phát lại cho đúng. Như vậy tính nguyên vẹn vẫn được coi là đảm bảo. Tính khả dụng bị vi phạm khi kẻ thù hay kẻ tấn công tìm cách ngăn chặn sự truy nhập dịch vụ của một hệ thống, làm tập thể người dùng bị khó khăn hoặc bị từ chối liên tục trong việc kết nối hay khai thác dịch vụ. Ví dụ điển hình nhất là trường hợp hệ thống bị tấn công từ chối dịch vụ (DoS: denial-of-service), sẽ được nghiên cứu chi tiết ở chương 8. Chúng ta có thể đưa ra rất nhiều ví dụ thực tế để minh họa (sẽ nêu và phân tích thêm sau này). Các kỹ thuật mật mã là các công cụ cơ bản nhằm xây dựng dịch vụ đảm bảo tính mật và tính nguyên vẹn.

A.2. Phân loại các đe dọa

Để đưa ra giải pháp đảm bảo các mục tiêu căn bản nói trên, nhà thiết kế giải pháp phải phân tích tìm hiểu tất cả các mối đe dọa có thể xảy ra đối với HTTT của mình, dựa trên hiểu biết chung về các loại đe dọa cơ bản. Có bốn loại cơ bản sau:

- Bóc tin mật (disclosure): kẻ tấn công tìm cách “nghe” lén/trộm (snooping) các thông tin mật, thường là thông qua kỹ thuật tóm bắt các gói tin gửi qua các điểm trung gian.

- Lừa đảo (deception): kẻ tấn công can thiệp thay đổi các thông tin làm người nhận hiểu nhầm hoặc xử lý nhầm, gây ra thiệt hại hoặc quyết định sai. Các tấn công cụ thể thường gọi là: sửa đổi (modification), cắt ghép (spoofing), từ chối phát, từ chối nhận...

- Gián đoạn (disruption): kẻ tấn công sửa đổi thông tin điều khiển làm hệ thống nạn nhân bị gián đoạn, phần nào rối loạn.

- Chiếm đoạt (usurpation): kẻ tấn công sửa đổi thông tin điều khiển qua đó cướp đoạt quyền điều khiển hệ thống hoặc phá hỏng hay làm ngừng trệ hệ thống.

Trong các loại tấn công nói trên lại có nhiều dạng tấn công cụ thể, hoặc mô hình cụ thể khác nhau. Các dạng tấn công bóc tin mật thường là thụ động, tức là kẻ địch không sửa đổi thông tin. Các dạng tấn công khác, chủ động tác động lên thông tin và dữ liệu, thường là nguy hiểm hơn, tùy vào mức độ tác động. Thậm chí kẻ địch có thể

tác động lên thông tin để tìm cách thao túng toàn bộ kênh thông tin mà các bên tham gia liên lạc không hề biết. Điển hình nhất là sơ đồ tấn công *kẻ-ngồi-giữa* (the-man-in-the-middle attack), trong đó kẻ tấn công nham hiểm, có khả năng xen vào giữa hai bên A và B, bóp méo thông tin gửi từ cả hai phía mà không để lộ ra. Cơ chế bóp méo hai phía này là rất nham hiểm, khiến cho cả hai bên không thể nhận ra, vì hai sự bóp méo từ hai phía là rất khớp nhau, không để xảy ra sai lệch.

Để đảm bảo bao quát hết các mối đe dọa và có giải pháp chắc chắn, cần lưu ý hai nguyên tắc quan trọng trong đánh giá phân tích các mối đe dọa:

- Phải tính đến tất cả các khả năng mà kẻ địch có thể thâm nhập. Kẻ địch thường thử mọi cách có thể được để hòng thâm nhập phá hoại cho nên không được phép giả sử rằng kẻ sẽ tấn công chỉ ở một số điểm này mà không ở những chỗ khác, nói cách khác phải đề phòng cả những khả năng khó tin nhất. Nguyên tắc này làm cho việc thẩm định về bảo mật trở nên rất khó, do tất cả các khả năng bị phá hoại phải được tính đến.

- Tài sản phải được bảo vệ cho đến khi hết giá trị sử dụng hoặc hết ý nghĩa mật.

Nếu chúng ta không đứng vững trước các loại tấn công trên, nhiều thiệt hại trong hệ thống máy tính có thể xảy ra:

1. Xóa: kẻ địch xóa tệp dữ liệu quan trọng hoặc sao chép dè.

2. Sửa đổi:

- Sửa đổi chương trình có thể gây ra chương trình bị treo ngay lập tức hoặc một thời điểm nào đó sau này (logic bomb – "mìn hẹn giờ"). Hoặc nó có thể khiến cho chương trình hoạt động và tạo ra những hiệu ứng không trong thiết kế, chẳng hạn như sửa đổi trái phép quyền truy nhập.

- Sửa đổi dữ liệu có thể gây ra bằng nhiều hình thức: nhồi nhét để chế biến các thông báo giả (salami attack).

3. Can thiệp: Ăn trộm chương trình, dữ liệu. Phá hoại tính bí mật của các dữ liệu thông qua các phương pháp nghe trộm (wiretaping, monitoring, electromagnetic radiation...).

Rất khó phát hiện những xâm phạm vào tính **mật** của tài sản vì chương trình/dữ liệu không hề bị thay đổi mà chỉ bị lộ bí mật.

- Truyền dữ liệu giữa các điểm phân tán dễ làm bộc lộ dữ liệu, tạo nên nhiều điểm tấn công cho những kẻ xâm nhập để sửa đổi dữ liệu.

- Chia sẻ tài nguyên và điều khiển truy nhập trở thành một vấn đề hóc búa.

A.3. Chính sách và cơ chế

Khởi nguồn của một giải pháp ATTT là việc xây dựng một bộ chính sách. *Chính sách* (policy) là một phát biểu ở mức khái quát, quy định những điều nên làm và không nên làm. Một định nghĩa khái quát về giải pháp ATTT chính là tập hợp các chính sách xây dựng nó. Chính sách này được xây dựng trên cơ sở đã khảo sát phân tích kỹ các mối đe dọa tiềm năng. Chính sách chỉ là một phát biểu chỉ ra sự yêu cầu, mong muốn của lãnh đạo tổ chức. Tự nó không thực hiện được chính nó, mà cần một *cơ chế*

(mechanism) hoạt động, cài đặt cụ thể để có thể áp đặt những yêu cầu, mong muốn này vào đời sống công việc hằng ngày của tổ chức và hệ thống thông tin của nó. Cơ chế thể hiện một hệ thống quy định chi tiết, trong đó bao gồm những quy định kỹ thuật và những quy định mang tính thủ tục.

Thông thường đưa ra tập chính sách không phải là một cá nhân nào đó, mà (và nên) là một hội đồng, quy tụ các chuyên gia và lãnh đạo quản lý, không chỉ trong giới hạn chuyên môn công nghệ thông tin mà còn các mảng khác như nghiệp vụ, tài chính, quản lý, nhân sự. Tức là mọi mặt hoạt động của công ty, vì an ninh thông tin chung sẽ ảnh hưởng và bị ảnh hưởng tới mọi khía cạnh, góc độ trong một hệ thống doanh nghiệp, tổ chức. Chính sách có thể biểu đạt bằng nhiều ngôn ngữ khác nhau, có thể bằng các mệnh đề toán học, chính xác cao nhưng khó hiểu, hoặc ngôn ngữ tự nhiên, dễ hiểu nhưng dễ gây nhập nhằng, thiếu chính xác. Vì vậy, người ta đã thiết kế công cụ riêng, được gọi là ngôn ngữ chính sách (policy languages) để đảm bảo sự cân bằng giữa tính chính xác và sự dễ hiểu.

Vì có thể được tạo ra từ nhiều nguồn gốc, nhiều quan điểm của nhiều chuyên gia lĩnh vực khác nhau, các chính sách có thể mâu thuẫn nhau, dẫn tới khó khăn trong việc tích hợp chung vào hệ thống. Sự vênh nhau trong chính sách có thể dẫn tới những điểm yếu, những “lỗ hổng” tiềm năng mà một kẻ đối địch có thể khai thác để tấn công. Những điểm yếu hay “lỗ hổng” này thường được gọi là điểm dễ bị tổn thương, nhạy cảm về ATBM (security vulnerability). Vì vậy trong việc xây dựng chính sách, khâu tích hợp cần được làm rất cẩn thận để phát hiện và giải quyết các bất đồng có thể nảy sinh giữa các chính sách (thường tạo ra bởi các chuyên gia ở lĩnh vực khác nhau).

Mục đích chung của giải pháp an toàn thông tin chính là bảo vệ hệ thống, mà nói cho cùng chính là bảo vệ sự toàn vẹn của các chính sách an toàn, không để cho chúng bị vi phạm. Dưới góc độ này, chúng ta có thể thấy 3 mục tiêu cụ thể là: 1) phòng chống không cho kẻ tấn công có thể vi phạm (đấy là lý tưởng nhất); 2) phát hiện tấn công vi phạm (càng sớm càng tốt); và 3) khôi phục sau tấn công, khắc phục hậu quả: sau khi đẩy lùi tấn công, khắc phục tình hình, khôi phục sự đảm bảo của các chính sách.

A.4. Kiểm tra và kiểm soát

Chỉ có chính sách và cơ chế là chưa đủ vì trong thực tế, một cơ chế xây dựng nên có đáp ứng tốt hoặc tồi cho việc đảm bảo áp đặt được chính sách đó. Ta cần phải có công cụ kiểm tra, đánh giá độ đáp ứng của cơ chế đối với việc áp đặt chính sách, tức là trả lời câu hỏi “liệu có thể tin đến mức độ nào khả năng một hệ thống có đáp ứng đúng những yêu cầu đặt ra cho nó?”. Công cụ kiểm tra và kiểm soát (assurance) sẽ cho phép ta điều khiển tốt hơn việc đồng khớp được chính sách và cơ chế. Để làm được điều này, các kỹ thuật tiêu biểu của công nghệ phần mềm có thể được áp dụng trong toàn bộ quá trình xây dựng giải pháp phần mềm; đó là các bước kỹ thuật: xây dựng *đặc tả* (specification), *thiết kế* (design) và *cài đặt* (implementation).

Đặc tả là một kỹ thuật đi liền với pha *phân tích yêu cầu* (requirement analysis) trong công nghệ phần mềm. Các yêu cầu ở đây chính là các chính sách (thường phát biểu ở dạng khái quát) và các đặc tả sẽ cho phép mịn hóa các yêu cầu thành các yêu cầu nhỏ hơn, các bước công việc với yêu cầu riêng phải làm để thỏa mãn được một yêu cầu khái quát của chính sách. Các đặc tả cũng có thể được biểu đạt được bằng cả hai ngôn ngữ, hình thức (mệnh đề toán học) và phi hình thức (ngôn ngữ tự nhiên), cũng có thể ở các cấp độ khác nhau của khái quát (high-level) hay chi tiết, cụ thể (low-level). Đặc tả khái quát thường dùng cho mô tả hệ thống chung hoặc các module phân hệ lớn, còn đặc tả chi tiết áp dụng cho các module, thành tố nhỏ bên trong.

Thiết kế là công việc đưa ra các kiến trúc, các mô hình cài đặt nhằm đảm bảo hệ thống hoạt động đúng theo yêu cầu của đặc tả. Thông thường bản thiết kế là một tập hợp các sơ đồ thể hiện việc giải quyết theo từng mức trừu tượng. Ban đầu hệ thống được nhìn như một sơ đồ khái quát cao, sau đó sẽ được làm mịn dần bằng các sơ đồ bộ phận chi tiết hơn, có mức trừu tượng thấp dần, cho đến khi đạt mức chi tiết có thể sử dụng trực tiếp cho việc lập trình tạo mã cho hệ thống máy tính. Việc cài đặt là sự hiện thực hóa các sơ đồ chi tiết, cho từng phân hệ, từng module và tích hợp lại.

Quá trình thực hiện giải pháp thông qua các mức đặc tả, thiết kế và cài đặt, sẽ giúp cho việc kiểm soát được dễ dàng, vì tất cả mọi khâu thực hiện đều có định nghĩa rõ ràng, cái vào, cái ra cụ thể, cũng như bộ tài liệu xây dựng dần, chu đáo. Phương châm chung là mỗi công việc to hay bé phải có đặc tả yêu cầu và mô hình thực hiện, từ đó dễ dàng đánh giá chất lượng sản phẩm cuối và độ thỏa mãn với mục tiêu ban đầu.

A.5. Xung quanh chủ đề điều hành (operational issues)

Phân tích chi phí – lợi nhuận (cost – benefit analysis)

Đây là một chủ đề quan trọng, phải được xem xét kỹ càng khi lựa chọn giải pháp. Giải pháp cho ATTT đối với một hệ thống cụ thể có thể có nhiều, có thể do tổ chức tự xây dựng nên, hoặc do các công ty tư vấn khuyến nghị, mỗi giải pháp sẽ có những ưu – nhược điểm riêng cùng với giá thành khác nhau. Đôi khi một giải pháp đơn giản là không làm gì mới cả, cũng là một giải pháp chấp nhận được, nêu phân tích cho thấy chi phí để khôi phục hệ thống (chẳng hạn như chỉ là việc quét, diệt virus và cài lại các phần mềm thông dụng) là rẻ tiền hơn so với các giải pháp ATTT được nêu.

Phân tích rủi ro (risk analysis)

Đây cũng là một vấn đề điển hình thường được cân nhắc trước khi đầu tư cho một giải pháp an ninh, thường là tốn kém đáng kể. “Có bảo vệ hay không?”, “bảo vệ đến mức độ nào?” là các câu hỏi cần quyết định. Dựa vào việc phân tích rủi ro sẽ có thể xảy ra nếu không thực hiện biện pháp cụ thể nào đó, người ta có thể đưa ra quyết định tương ứng, để chọn lựa giải pháp hiệu quả nhất, vừa giảm thiểu rủi ro, vừa không gây chi phí lớn quá mức chịu đựng.

Va chạm với luật và lệ

Một số công ty đa quốc gia thường gặp vấn đề này khi phát triển một chính sách an toàn chung trên nhiều quốc gia mà họ đặt tổ chức kinh doanh. Nhiều khi những chính sách bảo mật đã được hoàn thiện và chấp nhận tại chính quốc và một số quốc gia nào đó lại không thể được chấp nhận, hoặc gây sự phản đối nào đó (do các lễ thói, thói quen không thành văn) ở môi trường của một quốc gia mà công ty này bắt đầu khai phá thị trường. Vì vậy, những chính sách ATTT cũng cần phải được xem xét lại, có sự thương lượng và chỉnh nắn cho phù hợp với môi trường mới. Công ty Google vì không làm tốt điều này mà phải rút, không tổ chức kinh doanh tại thị trường Trung Quốc.

Các vấn đề xung quanh con người và tổ chức

Quyền lực và trách nhiệm. Hai điều này phải sánh đôi cân bằng. Một người được trao trách nhiệm phụ trách về an ninh thông tin, thường là một chuyên gia ICT có tuổi đời còn trẻ, cũng phải được trao một quyền lực đúng mức căn cứ theo hệ thống cấp bậc trong tổ chức. Thiếu quyền lực tương ứng phù hợp, người dù có năng lực cao cũng không thể hoàn thành trách nhiệm khó khăn, đặc biệt trong một địa hạt mà sự thiếu hiểu biết về nó có thể có ở các cấp rất cao. Chẳng hạn nếu một vị trí lãnh đạo của công ty coi thường không tuân thủ quy định nào đó (ví dụ như về lựa chọn mật khẩu) mà phụ trách về an ninh đặt ra, thái độ đó sẽ lây lan ra các nhân viên khác, làm phá vỡ sự nghiêm minh chặt chẽ cần thiết để đảm bảo các chính sách được tuân thủ.

Ảnh hưởng của động cơ lợi nhuận. Các công ty doanh nghiệp thường bị lôi kéo rất mạnh bởi động cơ phải đầu tư cho có lãi, không đầu tư nhiều tiền vào dự án nào khi không sinh được lợi nhuận. Điều đó tạo một tình thế trớ trêu vì đầu tư vào ATTT sẽ tiêu tốn nhiều tiền mà không sinh ra lợi nhuận trực tiếp; người ta thường chỉ thăm thía sự cần thiết của ATTT khi đã bị thiệt hại đáng kể do bị tấn công khai thác các điểm yếu của hệ thống thông tin.

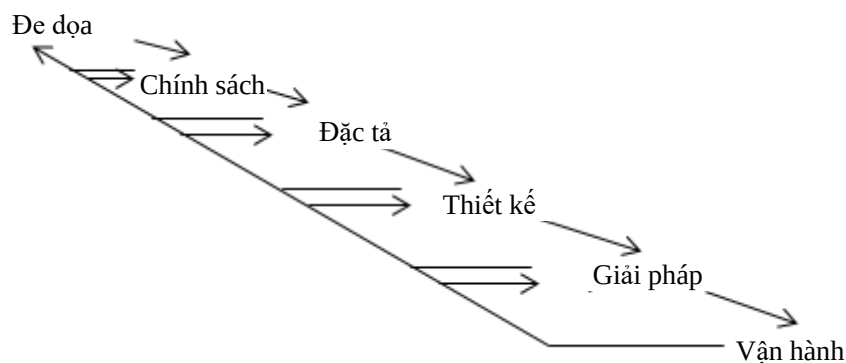
Quan hệ giữa con người. Các giải pháp cần có các chính sách thỏa đáng xem xét các mối đe dọa có thể đến từ các đối tượng con người khác nhau; người ta thường tập trung quan tâm đến các khả năng tấn công từ bên ngoài mà ít chú ý đến các khả năng tấn công từ bên trong. Những mối đe dọa từ phía bên trong đương nhiên là nguy hiểm hơn nhiều và nên nhớ chúng có thể đến từ không chỉ nhân viên hiện thời của tổ chức, công ty mà còn từ các nhân viên cũ, đã thôi việc hoặc đã bị sa thải (loại này còn nguy hiểm hơn do bất mãn gây ra).

Chế tạo quan hệ xã hội (social engineering) là một chủ đề đáng nói ở đây: kẻ tấn công có thể giả mạo và bịa đặt những mối quan hệ với các cá nhân có vị trí quan trọng của một tổ chức, thông qua đó lừa gạt các nhân viên quản trị ICT (thường còn

trẻ) để chiếm quyền điều khiển các tài khoản quan trọng và ăn cắp thông tin quý giá của công ty.

A.6. Vòng đời an toàn thông tin

Toàn bộ khảo sát trên cho chúng ta một bức tranh toàn thể về quá trình xây dựng một giải pháp an toàn thông tin. Tóm tắt lại, quá trình này gồm các bước: khảo sát tìm hiểu các mối đe dọa → xây dựng chính sách bảo vệ → xây dựng đặc tả yêu cầu từ khái quát đến cụ thể → xây dựng thiết kế mô hình → cài đặt giải pháp → vận hành và điều hành. Quá trình này có thể lặp lại nhiều lần tạo thành các chu trình, được gọi là vòng đời an toàn thông tin. Sự lặp lại này thông thường được tiến hành khi có những yêu cầu mới nảy sinh, hoặc những sự thay đổi, đổi mới đến từ phía môi trường công việc, nghiệp vụ. Sự thay đổi của các chức năng thuần túy nghiệp vụ có thể dẫn đến những mối đe dọa mới, tức là làm nảy sinh việc cập nhật và hoàn thiện bộ chính sách,... nghĩa là chúng ta bắt đầu một chu trình mới để cập nhật lại giải pháp ATTT.



Hình vẽ về vòng đời an toàn thông tin

B. NỀN TẢNG CƠ SỞ CỦA NGƯỜI KỸ SƯ AN TOÀN THÔNG TIN

Ở trên chúng ta đã làm quen với một cách nhìn toàn thể vào bài toán xây dựng giải pháp an toàn thông tin cho một hệ thống thông tin cụ thể, nó thể hiện phần nào cái toàn cảnh, khó khăn và thách thức mà một người chuyên gia ATTT (chịu trách nhiệm cao) phải đương đầu. Một kỹ sư trẻ mới tốt nghiệp đại học thì không bị yêu cầu phải có những kiến thức đủ sâu và rộng để bao quát hết, nhưng khung nhìn trên cho thấy thực tế đòi hỏi những gì ở một chuyên gia ATTT và tạo ra động lực để một sinh viên có thể phấn đấu trong quá trình học đại học cũng như đoạn đường rèn luyện lâu dài sau đó để có thể trở thành một chuyên gia thực thụ.

Giáo trình này sẽ cung cấp cho các bạn sinh viên cơ sở ban đầu về học vấn, về các phương pháp kỹ thuật cơ bản trong an toàn thông tin và quan trọng nhất là một phương pháp tư duy phân tích bài bản, hệ thống để từ đó các bạn có thể tự mình tiếp

tục rèn luyện, hoàn thiện tới những trình độ cao hơn trong nghề nghiệp chuyên môn, đặc biệt là khi đã có cơ hội cọ sát thực tế khi đã ra trường.

Mục này sẽ đưa ra một cái nhìn lướt về các kiến thức cơ sở sẽ được trình bày trong toàn giáo trình. Với người kỹ sư, có bốn thuật ngữ và cũng là phạm trù cơ bản khi nói về ATTT là: điểm yếu, dễ tổn thương (vulnerability) của hệ thống; mối đe dọa (threat); tấn công (attack); biện pháp phòng chống (control, security measure). Ba phạm trù đầu phản ánh các mức độ của kiến thức của chúng ta khi khảo sát các khả năng một hệ thống có thể bị tấn công cho đến khi những loại tấn công thực sự đã xảy ra. Mục A của chương này đã giới thiệu khá rõ nét về các phạm trù này.

Phạm trù cuối bao gồm tất cả những phương pháp có thể có để loại trừ các mối nguy hiểm và các tấn công thực sự. Có thể tạm liệt kê các biện pháp để điều khiển kiểm soát an toàn và bảo mật của một HTTT như sau:

1. Điều khiển thông qua phần mềm:

– Các tiêu chuẩn về mã hóa, kiểm tra và bảo trì.

– Các hệ điều hành.

– Các cơ chế điều khiển riêng của các chương trình. Ví dụ: các hệ quản trị cơ sở dữ liệu lớn đều có cơ chế quản lý quyền truy nhập (access control).

2. Điều khiển thông qua phần cứng:

– Các thiết bị cho việc định danh người sử dụng hệ thống.

– Phần cứng cho các thuật toán mã hóa.

3. Điều khiển qua các chính sách (policies):

Như đã nói ở phần trên, ví dụ như các nội quy an toàn trong lao động (điển hình là quy chế về việc bắt buộc người sử dụng trong hệ thống liên tục định kỳ thay đổi mật khẩu).

B.1. Quan điểm xây dựng và cấu trúc chung của giáo trình

Như đã nói ở phần đầu chương, giáo trình được xây dựng theo tiếp cận truyền thống với tiếp cận dưới – lên (trình bày các kiến thức kỹ thuật cơ sở trước khi khảo sát các vấn đề ATTT trong thực tế), nhưng tác giả có chú ý đến quan điểm làm sao tiếp cận tốt nhất với nhu cầu nhân lực thực tế. Đó chính là lý do của sự ra đời chương mở đầu này. Về nội dung chính của giáo trình, theo tiếp cận truyền thống, chúng tôi lựa chọn trình bày trước những khối kiến thức kinh điển, đã được nghiên cứu sớm nhất trong lĩnh vực, như cơ sở lý thuyết mật mã và ứng dụng, bài toán xác thực, bài toán điều khiển quyền truy nhập; sau đó đi vào khảo sát một số nội dung chọn lọc trong rất nhiều bài toán mở của thực tế. Cấu trúc chung của giáo trình gồm bốn phần như sau.

Phần I có tên là “Cơ sở Lý thuyết Mật mã và Ứng dụng”, gồm năm chương từ 1 đến 5. Phần này trình bày một cách khái lược và đơn giản hóa các kiến thức cơ sở của Mật mã học, từ đó nêu lên những nguyên lý ứng dụng cơ sở của nó trong ATTT.

Phần II có tên là “Kiểm soát hệ thống”, gồm chương 6 và 7. Phần này trình bày khái quát về hai phương thức điều khiển an toàn then chốt là *xác thực* và *điều khiển truy nhập*.

Phần III có tên là “Khảo sát một số lĩnh vực cụ thể trong thực tế”, gồm các chương 8 và 9, trình bày một số nét khái quát trong hai lĩnh vực “nóng” của thực tế là *an ninh mạng Internet* và *mã độc và an toàn phần mềm*.

Phần IV là phần đọc thêm, chỉ gồm chương 10, trình bày một số kiến thức nâng cao về giao thức mật mã và ứng dụng rộng rãi của chúng trong nhiều lĩnh vực kể cả lý thuyết và thực tế của ATTT.

Đây là giáo trình nhằm phục vụ chính cho các sinh viên các chương trình khác nhau của Đại học Bách Khoa, bao gồm *hệ cử nhân kỹ thuật*, *hệ kỹ sư* và *kỹ sư tài năng*, *hệ cao học*. Mặc dù vậy giáo trình cũng có thể được sử dụng cho việc tự học (kết hợp với bộ *slides* trình bày của tác giả đăng tại trang web cá nhân). Để tiện phối hợp phục vụ giảng dạy cho các chương trình khác nhau, mỗi chương chính của giáo trình (từ 1 đến 9) thường bao gồm hai dạng kiến thức:

- Kiến thức chuẩn: có thể sử dụng cho chương trình cử nhân kỹ thuật và kỹ sư.
- Kiến thức mở rộng: có thể sử dụng cho chương trình kỹ sư tài năng (hoặc các chương trình đặc biệt tương đương) và chương trình cao học. Trong mỗi chương, mỗi mục thuộc phần mở rộng này đều được đánh dấu ★ để phân biệt.

Phần tiếp sau đây của chương sẽ đưa ra những mô tả khái quát cho mỗi khối kiến thức chính của giáo trình.

B.2. Các nội dung cơ bản của giáo trình

Giáo trình này chủ yếu trình bày về các kiến thức, phương pháp và kỹ thuật cơ sở trong xây dựng các biện pháp nói trên. Sau đây ta sẽ đi qua các phương pháp và chủ đề chính.

Ứng dụng khoa học mật mã

Ban đầu là một kỹ thuật mang tính thủ công, phát triển hẹp chủ yếu trong các lĩnh vực nhạy cảm đòi hỏi tính bảo mật cao như quân sự, ngoại giao, lý thuyết mật mã hay còn gọi là khoa học mật mã (KHMM) đã trở thành một chuyên ngành lớn, có chiều sâu về mặt lý thuyết và chiều rộng về ứng dụng thực tế. KHMM ngày nay đã trở thành một cơ sở lý thuyết đầy đủ cho việc xây dựng các phương pháp hình thức (có mô hình mang tính toán học, có khả năng chứng minh được, có thể phân tích định lượng) cho các kỹ thuật đảm bảo an toàn thông tin (nói chung, không chỉ riêng bảo mật) và cả các kỹ thuật phá an toàn, tấn công (được nghiên cứu để làm công cụ phản biện cho các kỹ thuật xây dựng). Tức là, KHMM đã trở thành một nền tảng cơ bản, ít nhất là về phương pháp hình thức, cho việc xây dựng và phân tích đánh giá các giải pháp ATTT (mà không chỉ giới hạn trong bảo mật). Dựa vào lý thuyết mật mã, ta có một công cụ nền

tăng để sáng tạo ra những mô hình thuật toán và xây dựng các kiến trúc an toàn bảo mật. Kinh điển nhất là mô hình truyền tin bảo mật (thường người ta chỉ nghĩ đến nó thông qua tên gọi KHMM), bên cạnh đó là xác thực danh tính, xác thực thông điệp, chia sẻ bí mật chung, các giao dịch an toàn đa dạng,...

Một cách tóm tắt, có thể định nghĩa KHMM là một lĩnh vực khoa học mà ở đó các nhà chuyên môn cố gắng xây dựng các *phương pháp hình thức* (formal method) để tạo dựng các hệ thống an toàn (secure system) với các tính năng hoạt động đa dạng, như lưu trữ và xử lý thông tin, truyền tin giữa các thành phần hệ thống, mà tất cả các tính năng phải được đảm bảo an toàn trong sự có mặt của các *thể lực đối địch* (adversary). Mặc dù lý thuyết mật mã đã phát triển rất nhanh (thực sự hình thành như một ngành khoa học từ đầu thập kỷ 50 của thế kỷ XX và phát triển nhanh trong khoảng 30 năm trở lại đây), những nền tảng kinh điển có thể nói là đã hình thành, chủ yếu là qua các khám phá trong khoảng trước và trong thập kỷ 80. Kinh điển này bao gồm lý thuyết về công cụ mật mã cơ sở như sau: hệ thống mật mã đối xứng (symmetric key cryptosystem), hệ mật mã phi đối xứng hay khóa công khai (public key cryptosystem), các hệ xác thực và chữ ký điện tử, các hàm băm (một chiều) mật mã, các giao thức thống nhất khóa và một số giao thức mật mã cơ bản khác.

Trình bày về kinh điển của một lý thuyết nặng về toán học trong khung cảnh của một trường đại học thiên về kỹ thuật ứng dụng là hơi khó, nhưng tác giả hy vọng đã đưa ra một tiếp cận phù hợp, cố gắng trình bày được các tư tưởng chính trong khi lược bỏ bớt các yếu tố nặng về phương pháp toán hình thức. Phần nào, có thể coi như giáo trình là một hướng dẫn làm quen với một ngành lý thuyết khó, cố gắng tóm tắt các ý tưởng quan trọng có sức thúc đẩy khả năng tư duy, đồng thời làm quen với việc sử dụng chúng vào thực tế.

Các phương pháp xác thực

Bài toán xác thực được coi là một bài toán cơ bản trong ATTT, trong đó hệ thống cần cung cấp giải pháp để cho các bên liên lạc có thể xác thực được danh tính đúng và sự có mặt tồn tại thực sự của nhau, cũng như sự đúng đắn, toàn vẹn của các thông điệp truyền gửi giữa chúng. Mục tiêu chính là phát hiện các kẻ giả mạo danh tính, hoặc thông tin bị giả mạo. Có nhiều phương pháp để giải quyết vấn đề, trong đó có phần lớn được xây dựng từ KHMM, nhưng cũng có những phương pháp khác. Chữ ký điện tử chính là một công cụ cơ bản để giải quyết các vấn đề xác thực nêu trên, ứng dụng công cụ mật mã. Có các phương pháp xác thực danh tính khá phong phú như sử dụng mật khẩu (dựa trên bí mật mà đối tượng biết), sử dụng thẻ (đồ mà đối tượng có), ứng dụng đặc điểm sinh trắc học (yếu tố bản thể của đối tượng) và thông tin địa điểm (đối tượng đang ở đâu).

Các phương pháp điều khiển truy nhập

Điều khiển truy nhập là một chủ đề chính khác trong ATTT, xét từ góc độ hệ thống quản lý sự khai thác tài nguyên của người sử dụng (NSD, user). Sau khi hệ thống

chấp nhận một NSD đăng nhập (nhờ vượt qua pha xác thực), hệ thống cần đưa ra các quyết định cho phép NSD được truy nhập các tài nguyên cụ thể nào (tệp dữ liệu, thư mục, cổng truyền tin,...) với các quyền khai thác cụ thể nào (đọc, ghi, xóa, thực hiện chương trình,...). Có nhiều mô hình khác nhau thể hiện nhiều góc độ xử lý vấn đề và miền ứng dụng của mô hình; đó là: mô hình ma trận truy nhập (Matrix Access Control), mô hình tùy nghi (discretionary access control, DAC), mô hình cưỡng chế (Mandatory AC), mô hình dựa vai trò (Role-based AC).

Các phương pháp và kỹ thuật ATTT của lĩnh vực chuyên biệt

Ta đã điếm qua các cơ sở nền tảng chung của ngôi nhà ATTT; ngoài ra còn rất nhiều chủ đề quan trọng khác nhưng nằm trong các lĩnh vực hẹp khác nhau của khoa học máy tính. Qua phần trình bày có tính dẫn dắt từ đầu chương, chúng ta có thể hình dung rằng bài toán ATTT là hết sức phức tạp, ở đây tất cả các yếu tố đều phải được tính đến để bảo vệ. Trong khi đó bản thân các hệ thống tin học cần bảo vệ lại hết sức đa dạng và phong phú làm cho các vấn đề cần nghiên cứu càng trải rộng ra, tưởng như không thể bao quát hết. Vì vậy, người ta có thể chia các vấn đề về ATTT thành các lĩnh vực cụ thể khác nhau với: ATBM trong mạng truyền tin, trong các hệ điều hành, trong xây dựng phần mềm, trong cơ sở dữ liệu hay trong các mô hình thương mại điện tử...

Các lĩnh vực hẹp này của ATTT cũng có nhiều vấn đề chung như bảo mật, đảm bảo tính toàn vẹn, xác thực danh tính, điều khiển truy nhập (tức là các vấn đề thuộc nền tảng chung) nhưng cũng có những vấn đề quan trọng mang yếu tố riêng của lĩnh vực mà ta không thể nêu hết ở đây. Trong phần sau của giáo trình, căn cứ vào thời lượng của một môn học trong chương trình đại học, tác giả chỉ chọn lọc trình bày một số chủ đề ATTT chuyên biệt có tính phổ biến cao nhất như trong ATTT trong mạng Internet, ATTT trong xây dựng chương trình phần mềm và đối phó với mã độc (đặc biệt là trong phần mềm ứng dụng Web). Chúng tôi cũng cung cấp một chương đọc thêm (chương 10), giới thiệu một cách hệ thống và khái quát về các giao thức mật mã và ứng dụng to lớn của chúng trong giao dịch an toàn nói chung, mà có thể ứng dụng trong các lĩnh vực khác nhau như thương mại điện tử, truyền thông mạng, CSDL...

Có thể nói lĩnh vực ATTT là một tòa nhà to lớn và đang phát triển rất nhanh. Tuy nhiên cả tòa nhà này vẫn được xây dựng trên những mô hình an toàn và bảo mật cơ bản như các hệ mật mã kinh điển, quản lý khóa và bí mật, xác thực, điều khiển truy nhập... Phía trên nền tảng này là nhiều tòa tháp riêng với những miền kiến thức rộng lớn mà đôi khi những chuyên gia làm việc trong đó cũng lầm tưởng là mình đang bao quát toàn bộ lĩnh vực ATTT. ***Giáo trình Cơ sở an toàn thông tin*** này cố gắng cung cấp cho các bạn sinh viên một cái nhìn tổng thể và một cơ sở học vấn vững chắc để các bạn tiếp tục củng cố, phát triển hoàn thiện sau này trong một ngành nghề chuyên môn liên quan.

Hy vọng các bạn tìm thấy sự thích thú với môn học này.

Chúc các bạn thành công!

Phần I

CƠ SỞ LÝ THUYẾT MẬT MÃ VÀ ỨNG DỤNG

Chương 1

CÁC KHÁI NIỆM CƠ SỞ & HỆ MÃ CỔ ĐIỂN

Chương này sẽ bắt đầu đưa bạn đọc làm quen với thế giới mật mã. Mặc dù là chương đầu, nhưng các khái niệm cơ sở được giới thiệu có tầm bao quát và khá trừu tượng. Chúng tôi hy vọng các ví dụ cụ thể sẽ hỗ trợ đắc lực. Các hệ mật mã cổ điển đã từ lâu không được sử dụng trong thực tế, nhưng chúng vẫn tạo ra những nguồn kiến thức quý giá, hỗ trợ đắc lực cho việc làm quen với lĩnh vực. Các chủ đề chính của chương như sau:

- Các khái niệm cơ sở;
- Một số hệ mật mã cổ điển;
- Đọc thêm: Lý thuyết về sự bí mật tuyệt đối (Shannon).

1.1. CÁC KHÁI NIỆM CƠ SỞ

Mật mã là một lĩnh vực khoa học chuyên nghiên cứu về các phương pháp và kỹ thuật đảm bảo an toàn và bảo mật trong truyền tin liên lạc với giả thiết sự tồn tại của các thế lực thù địch, những kẻ muốn ăn cắp thông tin để lợi dụng và phá hoại. Tên gọi trong tiếng Anh, Cryptology được dẫn giải nguồn gốc từ tiếng Hy Lạp, trong đó kryptos nghĩa là “che giấu”, logos nghĩa là “từ ngữ”.

Cụ thể hơn, các nhà nghiên cứu lĩnh vực này quan tâm xây dựng hoặc phân tích (để chỉ ra điểm yếu) các giao thức mật mã (cryptographic protocols), tức là các phương thức giao dịch có đảm bảo mục tiêu an toàn cho các bên tham gia (với giả thiết môi trường có kẻ đối địch, phá hoại).

Ngành Mật mã (cryptology) thường được quan niệm như sự kết hợp của hai lĩnh vực con:

1. Sinh, chế mã mật (cryptography): nghiên cứu các kỹ thuật toán học nhằm cung cấp các công cụ hay dịch vụ đảm bảo an toàn thông tin.

2. Phá giải mã (cryptanalysis): nghiên cứu các kỹ thuật toán học phục vụ phân tích phá mật mã và/hoặc tạo ra các đoạn mã giả nhằm đánh lừa bên nhận tin.

Hai lĩnh vực con này tồn tại như hai mặt đối lập, “đấu tranh để cùng phát triển” của một thể thống nhất là ngành khoa học mật mã (cryptology). Tuy nhiên, do lĩnh vực thứ hai (cryptanalysis) ít được phổ biến quảng đại nên dần dần, cách hiểu chung hiện nay là đánh đồng hai thuật ngữ cryptography và cryptology. Theo thói quen chung này, hai thuật ngữ này có thể dùng thay thế nhau. Thậm chí cryptography là thuật ngữ ưa dùng, phổ biến trong mọi sách vở phổ biến khoa học, còn cryptology thì xuất hiện trong một phạm vi hẹp của các nhà nghiên cứu học thuật thuần túy.

Mặc dù trước đây hầu như mật mã và ứng dụng của nó chỉ phổ biến trong giới hẹp, nhưng với sự phát triển vũ bão của công nghệ thông tin và đặc biệt là sự phổ biến của mạng Internet, các giao dịch có sử dụng mật mã đã trở nên rất phổ biến. Chẳng hạn, ví dụ điển hình là các giao dịch ngân hàng trực tuyến hầu hết đều được thực hiện qua mật mã. Ngày nay, kiến thức ngành mật mã là cần thiết cho các cơ quan chính phủ, các khối doanh nghiệp và cho cả cá nhân. Một cách khái quát, ta có thể thấy mật mã có các ứng dụng như sau:

- Với các chính phủ: bảo vệ truyền tin mật trong quân sự và ngoại giao, bảo vệ thông tin các lĩnh vực tầm cỡ lợi ích quốc gia.
- Trong các hoạt động kinh tế: bảo vệ các thông tin nhạy cảm trong giao dịch như hồ sơ pháp lý hay y tế, các giao dịch tài chính hay các đánh giá tín dụng...
- Với các cá nhân: bảo vệ các thông tin nhạy cảm, riêng tư trong liên lạc với thế giới qua các giao dịch sử dụng máy tính và/hoặc kết nối mạng.

1.1.1. Những kỹ nguyên quan trọng trong ngành mật mã

Thời kỳ tiền khoa học: Tính từ thượng cổ cho đến 1949. Trong thời kỳ này, khoa mật mã học được coi là một ngành mang nhiều tính thủ công, nghệ thuật hơn là tính khoa học.

Các hệ mật mã được phát minh và sử dụng trong thời kỳ này được gọi là các hệ mật mã cổ điển. Sau đây ta làm quen với hai ví dụ hệ mã rất nổi tiếng của thời kỳ này.

1. Một phép mã hóa (cipher) trong thời kỳ này là của Xe-da (Caesar's cipher), cách đây 2000 năm: các chữ cái được thay thế bằng các chữ cái cách chúng ba vị trí về bên phải trong bản alphabet:

DASEAR → FDVHDU

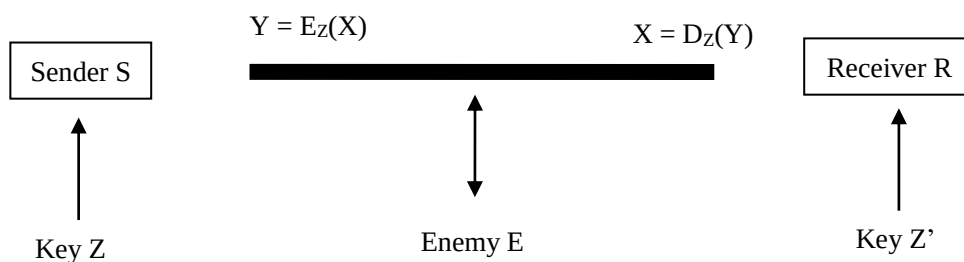
2. Vernam cipher (1926): người ta đem thực hiện phép XOR văn bản gốc (plaintext) với một chuỗi nhị phân ngẫu nhiên có độ dài bằng độ dài của văn bản gốc (chuỗi này là chính là khóa của phép mã hóa). Trong cipher loại này, khóa chỉ được dùng đúng một lần duy nhất. Vernam tin rằng cipher của ông là không thể phá được nhưng không thể chứng minh được.

Kỷ nguyên mật mã được coi là ngành khoa học: được đánh dấu bởi bài báo nổi tiếng của Claude Shannon “Communication theory of secrecy systems”, được công bố năm 1949. Công trình này dựa trên một bài báo trước đó của ông mà trong đó ông cũng đã khai sáng ra ngành khoa học quan trọng khác, *lý thuyết thông tin* (information theory). Bài báo năm 1949 của Shannon đã đặt nền móng cho việc áp dụng công cụ toán, cụ thể là xác suất, trong xây dựng mô hình và đánh giá tính mật của các hệ mã mật.

Tuy nhiên sự bùng nổ thực sự trong lý thuyết về mật mã (Cryptology) chỉ bắt đầu từ bài báo của hai nhà bác học Diffie và Hellman, “*New directions in cryptography*”, được công bố vào năm 1976. Trong đó, các ông này đã chứng tỏ rằng trong truyền tin bí mật, không nhất thiết là cả hai bên đều phải nắm khóa bí mật (tức bên gửi phải làm cách nào đó chuyển được khóa mật cho bên nhận). Hơn nữa họ đã lần đầu tiên giới thiệu khái niệm về *chữ ký điện tử* (digital signature).

Mặc dù mật mã có thể coi là một ngành toán học phát triển cao, đòi hỏi tư duy cao để nắm được các thành tựu hiện đại của nó, nhưng cơ sở xuất phát ban đầu của nó lại là một mô hình thực tiễn khá đơn giản như sau.

1.1.2. Mô hình truyền tin mật cơ bản



Hình 1.1. Mô hình truyền tin bảo mật

Chúng ta xem xét mô hình cơ bản của bài toán truyền tin mật. Khác với quan niệm truyền tin thông thường, mô hình này đưa thêm vào các yếu tố mới, đó là khái niệm kẻ địch ẩn giấu. Vì vậy giải pháp chống lại là sự đưa vào các khối xử lý mã hóa (encryption) và giải mã (decryption).

Các hoạt động cơ bản được tóm tắt như sau. Người phát S (sender) muốn gửi một thông điệp (message) X tới người nhận R (receiver) qua một kênh truyền tin (communication channel). Kẻ thù E (enemy) lầy/nghe trộm thông tin X. Thông tin X là ở dạng đọc được, còn gọi là bản rõ (plaintext). Để bảo mật, S sử dụng một phép biến đổi mã hóa (encryption), tác động lên X, để chế biến ra một bản mã Y (cryptogram, hay ciphertext), không thể đọc được. Ta nói bản mã Y đã che giấu nội dung của bản rõ X ban đầu. Giải mã (decryption) là quá trình ngược lại cho phép người nhận thu được bản rõ X từ bản mã Y.

Để bảo mật, các khối biến đổi sinh và giải mã là các hàm toán học với tham số khóa (key). Khóa là thông số điều khiển mà sở hữu kiến thức về nó thông thường là hạn chế. Thông thường khóa (Z) chỉ được biết đến bởi các bên tham gia truyền tin S và R.

Sơ đồ mô hình nói trên cũng thể hiện một điều hết sức cơ bản là toàn bộ tính bảo mật của cơ chế phụ thuộc vào tính mật của khóa, chứ không phải là tính mật của thuật toán hàm sinh hay giải mã (encryption và decryption). Điều này được khẳng định trong Luật **Kerckhoffs**, một giả thiết cơ bản của mật mã: Toàn bộ cơ chế sinh mã và giải mã ngoại trừ thông tin về khóa là không bí mật với kẻ thù. Điều này đi ngược với suy luận đơn giản của đa phần những người bên ngoài lĩnh vực. Họ thường cho rằng các thuật toán mật mã cần được giữ bí mật đặc biệt để đảm bảo an toàn cho hệ thống.

Như vậy khóa giữ vai trò trung tâm trong mô hình truyền tin mật. Những quan niệm về tổ chức quản lý khóa khác nhau sẽ đem đến những hệ thống mật mã có tính năng có thể hết sức khác nhau. Sau đây chúng ta sẽ xem xét hai hệ loại hệ thống mật mã cơ bản trong đó quan niệm tổ chức và sử dụng khóa là khá tương phản.

1.1.3. Hệ thống mật mã đối xứng (Symmetric Key Cryptosystem – SKC)

Loại hệ thống này còn gọi là hệ mật mã khóa bí mật (Secret Key Cryptosystem).

Trong mô hình của hệ thống này, khóa của hai thuật toán sinh mã và giải mã là giống nhau và bí mật đối với tất cả những người khác; nói cách khác, hai bên gửi và nhận tin chia sẻ chung một khóa bí mật duy nhất. Vai trò của hai phía tham gia là giống nhau và có thể đánh đổi vai trò, gửi và nhận tin, cho nên hệ thống được gọi là “mã hóa đối xứng”. Chúng ta sẽ sử dụng ký hiệu viết tắt theo tiếng Anh là SKC.

Hệ thống mật mã khóa bí mật đối xứng có những nhược điểm lớn trên phương diện quản lý và lưu trữ, đặc biệt bộc lộ rõ trong thế giới hiện đại khi liên lạc qua Internet đã rất phát triển. Nếu như trong thế giới trước kia, liên lạc mật mã chỉ hạn chế trong lĩnh vực quân sự hoặc ngoại giao thì ngày nay các đối tác doanh nghiệp khi giao dịch qua Internet đều mong muốn bảo mật các thông tin quan trọng. Với hệ thống khóa bí mật, số lượng khóa bí mật mà mỗi công ty hay cá nhân cần thiết lập với các đối tác khác có thể khá lớn và do đó rất khó quản lý lưu trữ an toàn các thông tin khóa riêng biệt này.

Một khó khăn đặc thù khác nữa là vấn đề xác lập và phân phối khóa bí mật này giữa hai bên, thường là đang ở xa nhau và chỉ có thể liên lạc với nhau qua một kênh truyền tin thông thường, không đảm bảo tránh được nghe trộm. Với hai người ở xa cách nhau và thậm chí chưa từng biết nhau từ trước thì làm sao có thể có thể thiết lập được một bí mật chung (tức là khóa) nếu không có một kênh bí mật từ trước (mà điều này đồng nghĩa với tồn tại khóa bí mật chung)? Có vẻ như chẳng có cách nào ngoài sử dụng “thần giao cách cảm” để hai người nay có thể trao đổi, thiết lập một thông tin bí mật chung?

Đây là một thách thức lớn đối với hệ thống mật mã khóa đối xứng. Tuy nhiên độc giả sẽ thấy câu hỏi này có thể được trả lời bằng giao thức mật mã thiết lập khóa mà sẽ được giới thiệu ở các chương sau.

1.1.4. Hệ thống mật mã khóa công khai hay phi đối xứng (Public Key Cryptosystem – PKC)

Ý tưởng về các hệ thống mật mã loại này mới chỉ ra đời vào giữa những năm 70 của thế kỷ XX. Khác cơ bản với SKC, trong mô hình mới này, hai khóa của thuật toán sinh mã và giải mã là khác nhau và từ thông tin khóa sinh mã, mặc dù trên lý thuyết là có thể tìm được khóa giải mã (có thể thử vét cạn) nhưng khả năng thực tế của việc này hầu như bằng không (bất khả thi về khối lượng tính toán). Chúng ta sẽ làm quen cụ thể với mô hình này trong chương 3.

Ý tưởng mới này cho phép mỗi thực thể cá nhân công ty chỉ cần tạo ra cho mình một cặp khóa, với hai thành phần:

- Thành phần khóa công khai, có thể đăng ký phổ biến rộng khắp, dùng để sinh mã hoặc để xác thực chữ ký điện tử (cụ thể trong chương 3).
- Thành phần khóa bí mật, chỉ dành riêng cho bản thân, dùng để giải mã hoặc tạo ra chữ ký điện tử.

Chỉ với cặp khóa này, thực thể chủ có thể giao dịch bảo mật với quảng đại xã hội, trong đó việc quản lý và lưu trữ có thể được tổ chức chặt chẽ mà việc phải tự nhớ thông tin mật là tối thiểu (giống như việc chỉ nhớ một mật khẩu hay một số PIN tài khoản ngân hàng).

1.1.5. Đánh giá tính bảo mật của các hệ mật mã

Các thuật toán, hệ thống mật mã được biết đến trên thế giới là không ít. Làm sao để ta có thể đánh giá được tính an toàn, hay tính bảo mật của mỗi một hệ mã đặt ra? Trên cơ sở nào chúng ta có thể thiết lập niềm tin nhiều hoặc không nhiều vào một hệ mã nào đó?

Ta có thể kết luận một hệ mã mật là *không an toàn* (insecure), bằng việc chỉ ra cách phá nó trong một mô hình tấn công (khái niệm sẽ giới thiệu sau đây) phổ biến, trong đó ta chỉ rõ được các mục tiêu về ATBM (security) không được đảm bảo đúng. Tuy nhiên, để kết luận rằng một hệ mã là an toàn cao thì công việc phức tạp hơn nhiều. Thông thường, người ta phải đánh giá hệ mã này trong nhiều mô hình tấn công khác nhau, với tính thách thức tăng dần. Để có thể khẳng định tính an toàn cao, cách làm lý tưởng là đưa ra một chứng minh hình thức (formal proof), trong đó người ta chứng minh bằng công cụ toán học là tính ATBM của hệ mã đang xét là tương đương với một hệ mã kinh điển, mà tính an toàn của nó đã khẳng định rộng rãi từ lâu.

Như đã nói trên, người ta phủ định tính an toàn của một hệ mã mật thông qua việc chỉ ra cách phá cụ thể hệ mã này trên một mô hình tấn công (attack model) cụ thể. Mỗi mô hình tấn công sẽ định nghĩa rõ năng lực của kẻ tấn công, bao gồm năng lực tài nguyên tính toán, loại thông tin mà nó có khả năng tiếp cận để khai thác và khả năng tiếp xúc với *máy mật mã* (thiết bị phần cứng có cài đặt thuật toán sinh và giải mã). Các mô hình tấn công thường được sắp xếp theo thứ tự mạnh dần của năng lực kẻ tấn công.

Nếu một hệ mật mã bị phá vỡ trong một mô hình tấn công căn bản (năng lực kẻ tấn công là bình thường) thì sẽ bị đánh giá là hoàn toàn không an toàn. Sau đây là một số mô hình tấn công phổ biến.

Tấn công chỉ-biết-bản-mã (ciphertext-only attack). Ở đây kẻ địch E chỉ là một kẻ hoàn toàn bên ngoài, tìm cách nghe trộm trên đường truyền để lấy được các giá trị Y, bản mã của thông tin gửi đi. Mặc dù kẻ địch E chỉ biết các bản mã Y, nhưng mục tiêu nó hướng tới là khám phá nội dung một/nhiều bản rõ X hoặc lấy được khóa mật Z (trường hợp phá giải hoàn toàn). Đây là mô hình tấn công căn bản nhất trong đó kẻ địch không có năng lực quan hệ đặc biệt (như một số hình thức tấn công sau), diện thông tin tiếp xúc chỉ là các bản mã. Rõ ràng nếu một hệ mã mà không đứng vững được trong mô hình này thì phải đánh giá là không đáng tin cậy.

Tấn công biết-bản-rõ (known-plaintext attack). Mặc dù tên gọi hơi dễ hiểu nhầm, thực chất trong mô hình này ta chỉ giả thiết là E có thể biết một số cặp X-Y (bản rõ và bản mã tương ứng) nào đó. Nguyên nhân E thu được có thể hoàn toàn tình cờ hoặc nhờ một vài tay trong là nhân viên cấp thấp trong hệ thống. Tất nhiên mục tiêu của E là khám phá nội dung các bản rõ quan trọng khác và/hoặc lấy được khóa mật. Rõ ràng mô hình tấn công này làm mạnh hơn so với *tấn công chỉ qua bản mã*: Việc biết một số cặp X-Y sẽ làm bổ sung thêm đầu mối phân tích; đặc biệt từ bây giờ E có thể dùng phép thử loại trừ để vét cạn không gian khóa (*exshautive key search*) và tìm ra khóa đúng tức là sao cho $\text{Enc}(K, X) = Y$.

Tấn công bản-rõ-chọn-sẵn (chosen-plaintext attack). Trong mô hình này, không những E thu nhận được một số cặp X-Y mà một số bản rõ X do bản thân E soạn ra (*chosen plaintext*). Điều này thoạt nghe có vẻ không khả thi thực tế, tuy nhiên ta có thể tưởng tượng là E có tay trong là một thư ký văn phòng của công ty bị tấn công, ngoài ra do một quy định máy móc nào đó tất cả các văn bản dù quan trọng hay không đều được truyền gửi mật mã khi phân phát giữa các chi nhánh của công ty này. Có thể nhận xét thấy rằng, việc được tự chọn giá trị của một số bản rõ X sẽ thêm nhiều lợi ích cho E trong phân tích quan hệ giữa bản mã và bản rõ để từ đó lần tìm giá trị khóa.

Một cách tương tự, người ta cũng sử dụng mô hình *tấn công bản-mã-chọn-sẵn (chosen-ciphertext attack)* trong đó kẻ địch có thể thu nhận được một số cặp X-Y mà Y là giá trị được thiết kế sẵn. Trong thực tế điều này có thể xảy ra nếu như kẻ địch có thể truy nhập được vào máy mật mã hai chiều (có thể sử dụng với cả hai chức năng là sinh mã và giải mã). Tất nhiên cả hai dạng tấn công rất mạnh nói trên kẻ thù đều có thể khôn ngoan sử dụng một chiến thuật thiết kế bản rõ (hay bản mã) chọn sẵn theo kiểu thích nghi (*adaptive*), tức là các bản rõ chọn sau có thể thiết kế dựa vào kiến thức phân tích dựa vào các cặp X-Y đã thu nhận từ trước.

Để đánh giá tính an toàn của một hệ mã mật (khi đã áp vào một hay một số mô hình tấn công cụ thể), người ta có thể áp dụng một trong các mô hình đánh giá với các mức độ mạnh đến yếu dưới đây:

Bảo mật vô điều kiện (unconditional security): Đây là mô hình đánh giá ATBM mức cao nhất, trong đó “vô điều kiện” được hiểu theo ý nghĩa của lý thuyết thông tin (information theory), trong đó các ý niệm về “lượng tin” được hình thức hóa thông qua các phép toán xác suất. Trong mô hình này, kẻ địch được coi là không bị hạn chế về năng lực tính toán, tức là có thể thực hiện bất kỳ khối lượng tính toán cực lớn nào đặt ra trong khoảng thời gian ngắn bất kỳ. Mặc dù có năng lực tính toán siêu nhiên như vậy, mô hình này chỉ giả thiết kẻ tấn công là người ngoài hoàn toàn (tức là ứng với mô hình tấn công chỉ-biết-bản-mã). Một hệ mật mã đạt được mức an toàn vô điều kiện, tức là có thể đứng vững trước sức mạnh của một kẻ địch bên ngoài (chỉ biết bản mã) có khả năng không hạn chế tính toán, được gọi là đạt đến *bí mật tuyệt đối (perfect secrecy)*.

Một cách khái quát, việc nghe trộm được bản mã đơn giản là chỉ cung cấp một lượng kiến thức zero tuyệt đối, không giúp gì cho việc phá giải mã của kẻ địch. Việc biết bản mã không đem lại chút đầu mối gì cho khả năng lần tìm ra khóa của hệ mã.

Bảo mật chứng minh được (provable security): Đây cũng là một mô hình đánh giá mức rất cao, lý tưởng trong hầu hết các trường hợp. Một hệ mật mã đạt được mức đánh giá này đối với một mô hình tấn công cụ thể nào đó, nếu ta có thể chứng minh bằng toán học rằng tính an toàn của hệ mật là được quy về tính NP-khó của một bài toán nào đó đã được biết từ lâu (ví dụ bài toán phân tích ra thừa số nguyên tố, bài toán cái túi, bài toán tính logarit rời rạc...). Nói cách khác, ta phải chứng minh được là kẻ thù muốn phá được hệ mã thì phải thực hiện một khối lượng tính toán tương đương hoặc hơn với việc giải quyết một bài toán NP-khó đã biết.

Bảo mật tính toán được, hay bảo mật thực tiễn (computational security hay practical security): Đây là một trong những mức đánh giá thường được áp dụng nhất trong thực tế (khi những mức bảo mật cao hơn được cho là không thể đạt tới). Khi đánh giá ở mức này với một hệ mã cụ thể, người ta lượng hóa khối lượng tính toán đặt ra để có thể phá hệ mã này, sử dụng kiểu tấn công mạnh nhất đã biết (thường kèm theo đó là mô hình tấn công phổ biến mạnh nhất). Từ việc đánh giá được khối lượng tính toán này cùng thời gian thực hiện (với năng lực kẻ địch mạnh nhất có thể trên thực tế), và so sánh với thời gian đòi hỏi đảm bảo tính mật trên thực tế, ta có thể đánh giá hệ mã có đạt an toàn thực tiễn cao hay không. Đôi khi, cơ sở đánh giá cũng dựa vào một bài toán khó nào đó mặc dù không đưa ra được một chứng minh tương đương thực sự.

Ví dụ: Giả thiết một hệ mã X được sử dụng mã mật các loại văn bản hợp đồng có giá trị sử dụng trong 2 năm. Nếu như kẻ địch có năng lực tính toán mạnh nhất có thể cũng phải mất thời gian đến 20 năm để phá được (chẳng hạn sử dụng toàn bộ lực lượng tính toán của các công ty IT lớn như Microsoft hay Google), hệ mã X này có thể được đánh giá là đảm bảo mức an toàn thực tiễn.

Bảo mật tự tác (ad hoc security): Một số hệ mật mã riêng được một số công ty hoặc cá nhân tự chế để phục vụ mục đích đặc biệt dùng nội bộ. Tác giả loại hệ mật mã có thể sử dụng những lập luận đánh giá hợp lý nhất định dựa trên việc ước đoán khối lượng tính toán của kẻ địch khi sử dụng những tấn công mạnh nhất đã biết và lập luận về tính bất khả thi thực tiễn để thực hiện. Mặc dù vậy hệ mật mã này vẫn có thể bị phá bởi những tấn công có thể tồn tại mà chưa được biết tới đến thời điểm đó; vì vậy, thực tế bảo mật ở mức này hàm nghĩa không có một chứng minh đảm bảo thực sự, nên không thể coi là tin cậy với đại chúng.

1.2. MỘT SỐ HỆ MẬT MÃ CỔ ĐIỂN

Việc nghiên cứu các hệ mã mật (*cipher*) cổ điển là cần thiết để qua đó chúng ta có thể làm quen với các nguyên tắc cơ bản trong thiết kế và phân tích các hệ mật mã nói chung.

1.2.1. Mật mã một bảng thế (Monoalphabetic cipher)

Ở đây thuật toán dựa trên phép hoán vị trong một bảng chữ cái alphabet.

Ví dụ 1.1: Một cipher dựa trên một bảng hoán vị của tiếng Anh như sau

a	b	c	d	e	...	x	y	z
F	G	N	T	A	...	K	P	L

Qua bảng biến đổi có thể thấy a ➔ F, b ➔ G ... Qua đó sẽ có

Plaintext: a bad day

➔

Ciphertext: F GFT TFP

Như vậy, khóa trong một cipher loại này là một bảng hoán vị ($A \rightarrow F$, $b \rightarrow G, \dots$, $z \rightarrow L$) như trên, hoặc biểu diễn ngắn gọn hơn là bảng dòng thứ hai của phép biến đổi này, tức là FGNT...PL. Dòng thứ nhất của bảng biến đổi này là bảng chữ cái gốc, vì nó là cố định nên không được tính tới trong khóa. Dòng thứ hai, được gọi là bảng thay thế (substitution alphabet).

Chú ý rằng không nhất thiết phải dùng một bảng chữ cái mà ta có thể dùng bất cứ một thứ bảng ký hiệu nào đó.

Ví dụ 1.2: Ở đây bảng chữ bản rõ, *plaintext alphabet*, là một tập hợp của các xâu nhị phân với độ dài là 3.

Bảng biến đổi:

p.text	000	001	010	011	100	101	110	111
c.text	101	111	000	110	010	100	001	011

Do đó xâu nhị phân plaintext 100101111 sẽ được mã hóa thành 010100011.

Để giải mã một bản rõ nhận được từ thuật toán mật mã trên, người có bản mã ciphertext cần biết khóa, do đó yêu cầu một giao thức về trao khóa. Đơn giản nhất có thể thực hiện là người gửi tin ghi khóa ra đĩa và chuyển đĩa cho người nhận. Rõ ràng cách làm này đơn giản nhưng thực tế không an toàn. Trong thực tế người ta sử dụng nhiều giao thức phức tạp và tinh vi hơn.

Nếu như kẻ thù không biết được khóa thì liệu chúng có thể đoán được không? Hiển nhiên là điều đó phụ thuộc vào số lượng khóa có thể có (độ lớn của không gian khóa có thể có). Nếu kích thước của bảng alphabet là N thì số khóa có thể là $N! = N(N-1)\dots 1$ và được tính xấp xỉ theo công thức:

$$N! \approx (2\pi n)^{1/2} (n/e)^n$$

Cho $N = 26$, ta có $N! = 26! \approx 9^{26}$.

Chú ý rằng, số lượng bit được chuyển mật này được gọi là chiều dài của khóa.

Ví dụ 1.3: Chiều dài khóa của một cipher loại đang xét là $26 \cdot 5 = 130$ bits, chính là số lượng bit tin cần dùng để chuyển đi dòng thứ hai trong bảng chuyển vị trên. (Dòng thứ nhất đã được ngầm định là ABC...XYZ, nên không cần chuyển).

<i>Chú ý:</i> Không phải tất cả các cipher như trên là che giấu được nội dung của thông tin.								
<i>Ví dụ 1.4:</i> Sau đây là một cipher hầu như không làm thay đổi plaintext.								
a	b	c	d	e	...	x	y	z
A	B	C	D	E	...	X	Z	Y

Mật mã cộng (Additive cipher) – Mật mã Xeda (Ceasar)

Mật mã cộng (Additive cipher) là một mật mã một bảng thế đặc biệt, trong đó, phép biến đổi mã được biểu diễn thông qua phép cộng đồng dư như sau. Giả sử ta gán các giá trị từ A – Z với các số 1 – 25,0. Thế thì một chữ plaintext X có thể mã thành ciphertext Y theo công thức:

$$Y = X \oplus Z,$$

trong đó Z là giá trị của khóa, $\oplus$ là ký hiệu phép cộng đồng dư modulo 26.

Ví dụ 1.5: Xét mật mã một bảng thế sau đây:

a	b	c	d	e	...	x	y	z
D	E	F	G	H	...	A	B	C

Đây chính là mật mã Ceasar đã giới thiệu từ đầu chương, trong đó giá trị khóa là $Z = 3$: $D = a \oplus 3, E = b \oplus 3, \dots A = x \oplus 3, B = y \oplus 3, C = z \oplus 3$

Rõ ràng số lượng khóa có thể dùng được chỉ là 25 và số lượng bit cần thiết cho việc chuyển khóa là 5 ($2^4 < 25 < 2^5$). Có thể thấy rằng mật mã cộng có một không gian khóa rất nhỏ, do đó phép tìm kiếm vét cạn đương nhiên là khả thi. Trong phép tấn công này, địch thủ chỉ cần thử tất cả các khóa có thể (1 – 25) để thử giải mã và dễ dàng phát hiện ra khóa đúng khi giải ra một thông tin có nghĩa. Vì phép tìm kiếm này không cần sử dụng các quan sát tinh tế mà chỉ đơn giản là thử hết các khả năng, dựa vào sức mạnh tính toán của kẻ tấn công, nên nó cũng còn được biết với cái tên *tấn công vũ lực* (*brute force attack*)

Mật mã nhân tính (*multiplicative cipher*)

Bảng thế cũng có thể được xây dựng từ phép nhân đồng dư của chữ cái trong bảng gốc với giá trị của khóa:

$$Y = X \otimes Z$$

Trong đó $\otimes$ là phép nhân đồng dư với module 26.

Tuy nhiên chú ý rằng không phải tất cả các giá trị từ 1–25 đều có thể là khóa mà chỉ các giá trị nguyên tố cùng nhau với 26, tức là các số lẻ trừ 13. Do đó chỉ có 12 khóa cả thảy mà thôi.

Ví dụ 1.6: Nếu ta dùng khóa $Z = 2$

$$2 \otimes 1 = 2 \bmod 26 \text{ tức là } b \rightarrow c.$$

$$\text{nhưng } 2 \otimes 14 = 2 \bmod 26 \text{ tức là } o \rightarrow c$$

Rõ ràng khóa 2 không thỏa mãn, vì không tạo ra ánh xạ 1–1 từ bảng chữ gốc sang bảng thay thế. Sự kiện đồng thời có $b \rightarrow c$ và $o \rightarrow c$ sẽ làm cho ta không thể giải mã ciphertext c .

Để tăng số lượng khóa có thể, người ta có thể kết hợp cả *additive cipher* và *multiplicative cipher* để tạo ra *afine cipher*:

$$Y = \alpha \otimes X \oplus Z$$

$$X, Y, Z \in \{0, 1, 2, 3, \dots, 25\}$$

$$\alpha \in \{1, 3, 5, 7, 9, 11, 15, 17, 19, 21, 23, 25\}$$

Qua những khảo sát trên, ta có thể dễ dàng thấy các dạng đặc biệt của mật mã bảng thế (trong đó phép biến đổi mật mã là một hàm toán học đơn giản) là không an toàn ngay cả với tấn công tìm kiếm vét cạn. Tuy nhiên mật mã một bản thế tổng quát, sử dụng một hoán vị bất kỳ trên bảng chữ cái gốc, có không gian khóa là thường là đủ lớn để chống lại bất kỳ kẻ địch nào (ngay cả trong thế giới hiện đại) chỉ dùng tấn công vét cạn – cụ thể là với bảng chữ cái tiếng Anh (26 chữ), số lượng hoán vị có thể (tức số lượng khóa cần vét cạn) sẽ lên tới $26! \approx 9^{26}$!

Trong thời kỳ thiên nhiên kỳ đầu tiên (trước năm 1000), mật mã một bản thế được coi là không thể phá được. Tuy nhiên sau đó, các nhà nghiên cứu thời đó đã dần dần tìm ra phương pháp phá giải tốt hơn việc thử vét cạn không gian khóa; phương pháp này dựa trên những quan sát mang tính thống kê, chẳng hạn về sự xuất hiện không đồng đều của các chữ cái trong ngôn ngữ tự nhiên.

1.2.2. Phân tích giải mã theo phương pháp thống kê (Statistical cryptanalysis)

Dễ dàng quan sát một đặc tính của ngôn ngữ tự nhiên là sự xuất hiện (tần suất) không đều của các chữ cái được dùng khi diễn đạt một ngôn ngữ.

Ví dụ 1.7: Hãy theo dõi một đoạn văn bản sau đây trong tiếng Anh (nguồn [19]).

THIS IS A PROPER SAMPLE FOR ENGLISH TEXT. THE FREQUENCIES OF LETTERS IN THIS SAMPLE IS NOT UNIFORM AND VARY FOR DIFFERENT CHARACTERS. IN GENERAL THE MOST FREQUENT LETTER IS FOLLOWED BY A SECOND GROUP. IF WE TAKE A CLOSER LOOK WE WILL NOTICE THAT FOR BIGRAMS AND TRIGRAMS THE NONUNIFORM IS EVEN MORE.

Ở đây ta dễ dàng thấy tần suất xuất hiện của chữ cái X và A: $f_x = 1$ và $f_A = 15$.

Khái quát hơn, trong tiếng Anh căn cứ vào tần suất xuất hiện của các chữ cái trong văn viết, ta có thể chia 26 chữ cái thành năm nhóm theo thứ tự từ hay dùng hơn đến ít dùng hơn như sau:

- I: e
- II: t,a,o,i,n,s,h,r
- III: d,l
- VI: c,u,m,w,f,g,y,p,b
- V: v,k,j,x,q,z

Với những quan sát tương tự áp dụng cho các cặp (bigrams) hay bộ ba chữ (trigram), người ta thấy tần suất cao nhất rơi vào các cụm phổ biến sau:

- Th, he, in, an, re, ed, on, es, st, en at, to
- The, ing, and, hex, ent, tha, nth, was eth, for, dth.

Chú ý: Những quan sát này được phản ánh trên chính đoạn văn bản ví dụ tiếng Anh ở trên. Những quan sát này chỉ đúng với tiếng Anh và như vậy tiếng Việt của chúng ta sẽ có quy luật khác.

Sau khi đã có các quan sát như trên, người ta có thể dùng phương pháp đoán chữ và giải mã dựa trên việc thống kê tần suất xuất hiện các chữ cái trên mã và so sánh với bảng thống kê quan sát của plaintext. Ví dụ sau đây sẽ minh họa cụ thể phương pháp này.

Ví dụ 1.8: Giả sử ta thu được một đoạn mã một bảng thể như sau và cần phải giải tìm khóa của nó.

YKHLBA JCZ SVIJ JZB TZVHI JCZ VHJ DR IZXKHLBA VSS RDHEI DR YVJV
LBXSKYLBA YLALJVS IFZZXC CVI LEFHDNZY EVBLRDSY JCZ FHLEVHT
HZVIDB RDH JCLI CVI WZZB JCZ VYNZBJ DR ELXHDZSZXJHDBLXI JCZ
XDEFSZQLJT DR JCZ RKBXJLDBI JCVJ XVB BDP WZ FZHRDHEZY WT JCZ
EVXCLBZ CVI HLIZB YHVEVJLXVSST VI V **HZIKSJ** DR JCLI HZXZBJ
YZNZXDPEZBJ LB JZXCBDSDAT EVBT DR JCZ XLFCZH ITIJZEIJCVJ PZHZ
DBXZ **XDBILYHZY IZXKHZ** VHZBDP WHZVMVWSZ (nguồn [19]).

Đoạn mã trên bao gồm 338 chữ, thống kê tần suất như sau:

Letter:	A	B	C	D	E	F	G
Frequency:	5	24	19	23	12	7	0
Letter:	H	I	J	K	L	M	N
Frequency:	24	21	29	6	21	1	3
Letter:	O	P	Q	R	S	T	U
Frequency:	0	3	1	11	14	8	0
Letter:	V	W	X	Y	Z		
Frequency:	27	5	17	12	45		

Quan sát Z là chữ mã có tần suất lớn hơn hẳn các chữ cái còn lại nên rút ra:

$e \Rightarrow Z$ (tức là bản rõ của mã Z phải là e)

Quan sát những chữ mã có tần suất cao tiếp theo $f_j = 29, f_v = 27$

Đồng thời chú ý đến bộ ba jcz có tần suất cao, dễ thấy

$$f_{jcz} = 8 \rightarrow t \Rightarrow J, h \Rightarrow C$$

(suy luận jcz chính là từ bản rõ *the*)

Ngoài ra tiếp tục quan sát ta sẽ thấy một số phát hiện dễ nhận:

$a \Rightarrow V$ (đứng riêng, mạo từ *a*)

Liệt kê nhóm II gồm các chữ mã có tần suất xuất hiện cao (nhóm 1 là chỉ gồm Z)

J,V,B,H,D,I,L,C ứng với bản rõ của nhóm II: {t,a,o,i,n,s,h,r}

t, a h

Quan sát thấy có một cụm 3 là JZB ($\Rightarrow teB$), ta sẽ tìm nốt bản rõ của B bằng cách đơn giản sau: thay thế các khả năng nhóm 2 của B vào cụm này:

$JZB = te ?$
 teo
 ten
 $ter \rightarrow n \Rightarrow B$
 the
 tes

Tương tự ta thực hiện một số quan sát và suy đoán khác:

$VI = a ?$ as
 $an \rightarrow s \Rightarrow I$ (n đã có B rồi)
 $VHZ = a ?e$ ate
 $are \rightarrow r \Rightarrow H$ (t đã có J rồi)
 $JCLI = th?s \rightarrow i \Rightarrow L,$

Cuối cùng còn lại trong nhóm II: $o \Rightarrow D$

<i>a</i>	<i>b</i>	<i>c</i>	<i>d</i>	<i>e</i>	<i>f</i>	<i>g</i>	<i>h</i>	<i>i</i>	<i>j</i>
<i>V</i>				<i>Z</i>			<i>C</i>	<i>L</i>	
<i>k</i>	<i>l</i>	<i>m</i>	<i>n</i>	<i>o</i>	<i>p</i>	<i>q</i>	<i>r</i>	<i>s</i>	<i>t</i>
			<i>B</i>	<i>D</i>			<i>H</i>	<i>I</i>	<i>J</i>
<i>u</i>	<i>v</i>	<i>w</i>	<i>x</i>	<i>y</i>	<i>z</i>				

Tiếp tục phân tích nhờ các cụm từ (bản mã) tương đối ngắn:

$DBXZ = on?e \rightarrow c \Rightarrow X$
 $WZZB = ?een = \rightarrow b \Rightarrow W$
 $YVJV = ?ata \rightarrow d \Rightarrow Y$

Tuy nhiên cũng có trường hợp không chắc chắn:

$DR = o ?$
 on: loại vì $n \Rightarrow B$ rồi
 of:
 or: loại vì $r \Rightarrow H$ rồi
 ox :

Nhưng chưa rõ ràng: $f, x \Rightarrow R$

Tiếp tục một số luận đoán:

$WT = b ? \rightarrow y \Rightarrow T$

$BDP = no ? \rightarrow w \Rightarrow P$

Bây giờ từ đầu tiên sẽ là:

$YKHLBA = d-rin-$

$\rightarrow u \Rightarrow K, g \Rightarrow A$

Rõ ràng qua ví dụ trên ta thấy hệ mật mã một bảng thế có thể khá dễ dàng bị phá khi nó vẫn tiếp tục “bảo tồn” trong bản mã những quy luật ngôn ngữ trong bản rõ. Những quy luật này biểu hiện bằng những đặc thù thống kê thu được khi phân tích mỗi ngôn ngữ tự nhiên.

Một cách tổng quát, một hệ mã mật tốt cần phải tránh không cho các quy luật thống kê trong ngôn ngữ văn bản rõ bảo tồn ở một hình thức nào đó trong bản mã. Một cách lý tưởng, các bản mã của một hệ mã tốt sẽ không thể phân biệt được bằng thống kê khi với một mã sinh ngẫu nhiên.

1.2.3. Phương pháp bằng phẳng hóa đồ thị tần suất

Khoảng đầu thiên nhiên kỷ thứ hai, mật mã một bảng thế đã bị phá và các nhà khoa học đã dần nghĩ đến các nguyên tắc thiết kế mã tốt hơn, nhằm tránh bảo tồn các quy luật thống kê từ TIN sang MÃ (bản rõ sang bản mã). Ta sẽ xem xét một số mã như vậy sau đây.

Mã với bảng thế đồng âm (homophonic substitution ciphers)

Trong các cipher loại này, ánh xạ chữ cái TIN– MÃ không còn là 1–1 nữa mà là một – nhiều. Tức là mỗi chữ của bảng chữ cái tin sẽ được mã hóa thành một chữ trong một tập con các chữ mã nào đó. Mỗi chữ mã trong tập con này được gọi là homophone, tạm dịch là đồng âm.

Ví dụ 1.9:

Chữ tin	Đồng âm
A	17 11 25 64 2 19 4 31
I	22 95 14 21 79 54
L	12 93 71
N	64 13
O	65 28 15
P	23 73 36 53 20
T	41
E	64 7 8 47 ... (15 đồng âm)
...	...

Như vậy có thể thấy đây là một bảng biến đổi từ chữ tin sang đồng âm mã.

Tin	P	L	a	I	n	p	i	l	o	t
Mã	27	12	11	53	64	36	79	71	15	41

Thông thường người ta bố trí số lượng đồng âm ứng với mỗi chữ tin tỷ lệ với tần suất xuất hiện của chữ đó trong ngôn ngữ tự nhiên. Vì vậy, đồ thị tần suất của các chữ cái trong bản mã sẽ trở nên “bằng phẳng” tức là trong đó các đỉnh quá cao và thấp sẽ được kéo lại gần nhau, xung quang một đường thẳng nằm ngang. Mặc dù các cipher loại này là khó phá hơn nhưng chúng lại bị tăng thêm độ dư thừa so với tin gốc.

Sử dụng nhiều bảng thế (mã đa bảng thế)

Ví dụ 1.10:

Xét một hệ mã đơn giản với bảng chữ gồm bốn chữ cái $\{a,b,c,d\}$. Giả sử tần suất xuất hiện của mỗi chữ trong ngôn ngữ như sau: $P_a = 0.5, P_b = 0.05, P_c = 0.2, P_d = 0.25$

Ta dùng hai bảng thế và một chuỗi khóa để quyết định thứ tự hòa trộn hai bảng

Bảng thế 1

<i>P.text alph</i>	<i>A</i>	<i>b</i>	<i>c</i>	<i>d</i>
<i>C.text alph</i>	<i>B</i>	<i>D</i>	<i>A</i>	<i>C</i>

Bảng thế 2

<i>P.text alph</i>	<i>A</i>	<i>b</i>	<i>c</i>	<i>d</i>
<i>C.text alph</i>	<i>D</i>	<i>B</i>	<i>C</i>	<i>D</i>

Tạo mã bằng phương pháp trộn hai bảng thế theo khóa “12”

<i>X</i>	:	<i>aba</i>	<i>cada</i>	<i>da</i>	<i>ca</i>	<i>baa</i>
<i>Z</i>	:	<i>121</i>	<i>2121</i>	<i>21</i>	<i>21</i>	<i>212</i>
<i>Y</i>	:	<i>BBB</i>	<i>CBAB</i>	<i>AB</i>	<i>CB</i>	<i>BBD</i>

Ở ví dụ trên người ta đã hòa trộn hai bảng thế liên tục kế tiếp nhau. Nhờ đó phân bố tần suất xuất hiện của các chữ mã sẽ bị thay đổi so với tin và bằng phẳng hơn.

Mã đa bảng thế (polyalphabetic cipher): Trong hệ mã thể loại này, người ta dùng nhiều bảng thế theo phương pháp vừa giới thiệu trên.

Ta sẽ xét một hệ cipher cổ điển nổi tiếng loại này sau đây.

1.2.4. Vigenere cipher

Trong Vigenere Cipher, người ta dùng tất cả 26 bảng thế là sự thu được từ bảng gốc chữ cái tiếng Anh mà dịch đi từ 0 – 25 vị trí. Sự hòa trộn này có quy luật hoàn toàn xác định bởi khóa. Mỗi chữ của khóa sẽ xác định mỗi bảng thế được dùng.

	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v
0	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
1	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
2	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
3	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y
4	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
5	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
6	G	H	I	J	K	L	M	N	O	P	P	R	S	T	U	V	W	X	Y	Z	A	B
..	..																					
.	.																					
2	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
4																						
2	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
5																						

Ví dụ 1.11:

Keyword	:	r	a	d	i	o	r	a	d	i	o	r	a
Plaintext	:	c	o	d	e	b	r	e	a	k	i	n	g
Ciphertext	:	T	O	G	M	P	I	E	D	S	W	E	G

Như ở ví dụ trên, tất cả các chữ đứng ở vị trí chia 5 dư 1 trong plaintext sẽ được mã hóa bởi bảng thế R (a thành R). Tất cả các chữ tin đứng ở vị trí chia 5 dư 2 trong TIN sẽ được mã hóa bởi bảng thế A,...

Mặc dù có thể làm bằng phẳng hóa đồ thị tần suất rất tốt, mật mã đa bảng thế nói chung, Vigenere nói riêng, vẫn có thể phá giải được.

Phương pháp giải mã Vigenere

Ý tưởng của phương pháp này gồm ba bước như sau:

1. Đi tìm chu kỳ p (độ dài khóa).
2. Chia tách MÃ thành p đoạn phân mã, mỗi đoạn bao gồm các chữ ở vị trí $kp + i$ ($k = 1, 2, 3 \dots$; $i = 0, p - 1$), tức là được mã hóa theo bảng thế với chữ khóa chỉ số i .
3. Dùng phương pháp một bảng thế đã biết để giải từng đoạn phân mã (cụ thể là với mã Vigenere chỉ cần một phép dịch đúng).

Có nhiều cách để tìm được giá trị chu kỳ p , ở đây chúng tôi trình bày cách làm thông qua sử dụng khái niệm IC (Index of Coincidence), *độ đo sự trùng hợp*, được định nghĩa như là một phép đo một tính chất đáng quan tâm (sự xuất hiện không đồng đều của các ký tự) với một văn bản cho trước.

Hãy làm quen với khái niệm trừu tượng này thông qua ví dụ sau: giả sử ta có một cái túi vải kín trong đó có n viên kẹo có hình dáng giống hệt nhau lấy từ k loại khác nhau về mùi vị và màu sắc, mỗi loại đều có số lượng nhất định; nếu ta thò tay vào túi kín này và ngẫu nhiên nhặt ra 2 viên kẹo thì sự kiện 2 viên kẹo này hóa ra cùng loại

có thể xảy ra không? Đương nhiên là có, khả năng tồn tại sự kiện trùng hợp này có thể được “lượng hóa” thông qua chính xác suất của sự kiện này với phép thử đã nêu. Những người quan sát và suy luận tình tế có thể nhận biết rằng: 1) xác suất này sẽ khá lớn nếu có 1 loại kẹo có số lượng lớn hơn rất nhiều so với số còn lại; 2) xác suất sẽ nhỏ đi nhiều nếu số lượng các loại kẹo là xấp xỉ.

Theo định nghĩa, IC của một văn bản cho trước chính là xác suất của sự kiện 2 ký tự được lấy ngẫu nhiên từ đoạn văn bản đó là giống nhau (trùng hợp). Người ta thấy rằng IC của đoạn văn bản M với độ dài n , cũng có thể xác định qua công thức:

$$IC = \frac{\sum_{i=0}^{25} f_i (f_i - 1)}{n(n - 1)}$$

Trong đó, với mỗi chữ cái λ cho trước, f_λ là tần suất bắt gặp sự kiện phép thử nhậ ra hai con chữ ngẫu nhiên bất kỳ từ văn bản M đều thu được cùng chữ λ .

Số bảng thế (p)	1	2	3	4	5	...	10
IC	0.068	0.052	0.047	0.044	0.043	...	0.041

Letter	p_i	Letter	p_i	Letter	p_i	Letter	p_i
A	.082	H	.061	O	.075	V	.010
B	.015	I	.070	P	.019	W	.023
C	.028	J	.002	Q	.001	X	.001
D	.043	K	.008	R	.060	Y	.020
E	.127	L	.040	S	.063	Z	.001
F	.022	M	.024	T	.091		
G	.020	N	.067	U	.028		

$$IC(x) = \sum_{i=0}^{25} p_i^2 = 0.065$$

IC của các văn bản tiếng Anh ($p = 1$) đạt giá trị trong miền từ 0.065 đến 0.068. Khi qua mã hóa, IC sẽ giảm dần đi khi tăng dần số lượng bảng thế (hay tăng chiều dài khóa). Qua đó ta thấy IC thể hiện độ không đồng đều của các tần suất xuất hiện các chữ cái. Trong văn bản gốc, độ không đồng đều (lồi lõm) là lớn nhất nên IC là lớn nhất. Còn khi mã hóa với nhiều bảng thế, đồ thị tần suất được làm "bằng phẳng hóa" nên tất nhiên IC giảm đi. Sau đây là một thuật toán phù hợp để phát hiện chu kỳ p của một đoạn MÃ Vigenere nhờ sử dụng IC

1. Đặt $k = 1$.

2. Kiểm tra xem p có phải nhận giá trị k hay không.
 - 2.a. Chia mã thành k phân mã và tính IC của các phân mã.
 - 2.b. Nếu như chúng đều xấp xỉ nhau và đều xấp xỉ 0.065 thì $p = k$.
Nếu chúng khác nhau nhiều và nhỏ hơn nhiều so với 0.065 thì $p > k$.
3. Tăng k lên một đơn vị và lặp lại bước 2.

1.2.5. One-time-pad (Vernam cipher)

Mật mã One-time-pad được đề xuất bởi G. Vernam (1917); sau đó đã được chứng minh là đảm bảo bí mật tuyệt đối (perfect secrecy – 1949). Như tên gọi của nó, trong One-time-pad khóa được viết trên một băng (tape) dài và sử dụng đúng một lần. Đồng thời chuỗi khóa là chuỗi văn bản sinh ngẫu nhiên, có độ dài bằng văn bản sử dụng hoặc hơn. Thao tác mã hóa đơn giản là phép dịch theo bảng thể ứng với chữ khóa tương ứng hoặc XOR nếu xử lý theo chuỗi nhị phân.

$$\text{Sinh mã: } Y = X + Z \pmod{26}$$

$$\text{Giải mã: } X = Y - Z \pmod{26}$$

Vì vậy, One-time-pad có thể coi là mã Vigenere với khóa là một chuỗi ngẫu nhiên có độ dài đúng bằng văn bản, như ví dụ sau sẽ cho thấy.

Ví dụ 1.12:

X:	x	n	t	f	u	h	b	z	t
Z:	A	s	u	n	n	y	d	a	y
Y:	Y	G	O	T	I	G	F	A	S

Ở đây A được hiểu là dịch 1 nên $X + A = Y$

Chú ý rằng khóa chỉ được dùng đúng một lần, tức là vứt bỏ sau khi dùng. Nếu dùng lại thì không còn đảm bảo an toàn nữa.

★ 1.3. LÝ THUYẾT VỀ SỰ BI MẬT TUYỆT ĐỐI (SHANNON)

1.3.1. Bí mật tuyệt đối là gì?

Tại sao chúng ta nói mật mã One-time-pad đảm bảo bí mật tuyệt đối?

Claude Shannon đã trả lời những câu hỏi này trong một công trình khoa học đã đặt nền móng cho ngành khoa học mật mã hiện đại (Communication Theory of Secrecy Systems, 1949). Trong phần này, chúng ta sẽ làm quen với các khái niệm cơ bản quan trọng này. Như đã nói, để khảo sát và phân tích các hệ mật mã, trước hết ta cần định nghĩa mô hình tấn công áp dụng. Ở đây, chúng ta sử dụng mô hình tấn công thông thường và khái quát nhất, mô hình *chỉ-biết-bản-mã* (ciphertext-only attack), trong đó

kẻ tấn công Eve là người bên ngoài hoàn toàn nên chỉ có khả năng nghe trộm đường truyền.

Khái niệm *một hệ mật mã đạt được bí mật tuyệt đối* được hiểu là hệ mật mã này đứng vững trong mô hình tấn công *chỉ-biết-bản-mã* dù kẻ địch Eve mạnh đến đâu: tức là có thể giả sử rằng Eve có phương tiện cực kỳ hùng hậu (coi như vô hạn) để có thể tiến hành được bất cứ phép tìm kiếm vết cặn không gian khóa (hữu hạn) nào trong khoảng thời gian ngắn tùy ý.

Tất nhiên ta phải giả thiết rằng Eve có thể thu được (nghe trộm) một bản mã có *độ dài tùy ý* để có thể dùng phân tích tìm ra khóa mật mã. Yếu tố độ dài bản mã nghe trộm được là rất quan trọng. Các hệ mật mã dù không an toàn vẫn có thể không bị phá hoàn toàn, tức là Eve không thể tìm được khóa đúng duy nhất, nếu như độ dài bản mã bị nghe trộm là không đủ dài để phân tích. Các ví dụ sau đây sẽ minh họa rõ điều này.

Giả sử Eve nghe trộm một bản mã (cryptogram) Y được tạo ra từ một hệ mã hóa một bảng thế. Để tìm bản rõ tương ứng, Eve có thể sử dụng *tìm kiếm thử – vết cặn không gian khóa* (exhaustive key search). Với Y ngắn ta có thể tìm được nhiều bản rõ X cũng có thể tạo ra mã Y với khóa khác nhau tương ứng (các phép thế khác nhau). Ví dụ ta có đoạn mã sau:

AZNPTFZHLKZ

Ta có thể tạo ra ít nhất là hai đoạn bản rõ tương ứng bằng hai bảng thế như sau:

Ví dụ 1.13:

Bảng thế 1

a	B	c	D	E	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
K	B	C	D	T	E	G	I	J	M	O	L	A	Q	R	H	S	F	N	P	U	V	W	X	Z	Y

Bảng thế 2

a	B	c	d	E	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
L	P	H	N	Z						K	T					A		F						E	

Do đó cùng đoạn mã này sẽ có hai bản rõ tương ứng với hai bảng thế trên:

Mã:	A	Z	N	P	T	F	Z	H	L	K	Z
Bản rõ 1:	m	y	s	t	e	r	y	p	l	a	y
Bản rõ 2:	r	e	d	b	l	u	e	c	a	k	e

Cả hai chuỗi “mysteryplay” và “redbluecake” đều có thể giả định là 2 thông điệp có nghĩa hợp lý (đã loại bỏ bớt dấu trắng).

Ví dụ 1.14:

Với MÃ ‘HLKZ’ có thể dễ dàng tìm ra bốn TIN tương ứng:

C.text:	H	L	K	Z
P.text1:	p	l	a	y
P.text2:	c	a	k	e
P.text3:	m	i	s	t
P.text4:	w	a	s	h

bằng các bảng thế như sau:

a	b	C	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
K										L					H									Z	
L		H		Z						K															
										L		H								K		Z			

(Bảng trên bỏ trống những ký tự thay thế giống như gốc)

Qua các ví dụ 1.13 – 1.14, có thể thấy được rằng đối với mã một–bảng–thế, khi bản mã còn tương đối ngắn thì luôn luôn tồn tại cùng lúc nhiều bản rõ có nghĩa tương ứng (với khóa dự đoán tương ứng).

Tuy nhiên với bản mã có độ dài trên 50 trở lên thì sẽ chỉ có duy nhất một bản rõ plaintext thỏa mãn, tức chính nó là bản rõ (với khóa tương ứng) cần tìm. Như vậy, nếu như Eve – nhà phân tích giải phá mã (cryptanalyst) – “tóm” được một đoạn mã có độ dài đủ lớn, thì nói chung luôn luôn có thể phá được mã loại một–bảng–thế này.

Trong ví dụ sau đây, ta sẽ quan sát một quá trình cụ thể giải phá mã cộng tính. Có 26 khóa là 26 khả năng để thử. Eve sẽ nghe trộm và lần lượt bắt được từng ký tự mã được phát trên đường truyền. Mỗi khi nghe được thêm một từ mã thì E tiến hành thử luôn cả 26 khả năng để tìm bản rõ có nghĩa luôn. Khi mới nghe trộm được từ mã đầu tiên thì khả năng của cả 26 khóa đều ngang ngửa nhau (xác suất đoán đúng đều nhỏ, cỡ nhỏ hơn 0.1), khi nghe trộm được từ khóa 2, 3... thì các xác suất sẽ thay đổi, hầu hết là tiếp tục giảm đi, trừ trường hợp với khóa 15. Khi nghe được từ mã 5 thì xác suất ứng với khóa 15 sẽ là 1 trong khi các xác suất khác đều là không; tức là khóa 15 là khóa đúng (chữ consi ứng với nó là đoạn đầu của một số từ có nghĩa trong tiếng Anh như consider, consideration...).

Ví dụ 1.15: Hãy xét một hệ mã cộng với 26 khóa khác biệt (“đẩy” 0 – 25 vị trí). Giả sử ta bắt được MÃ = “sdchx”. Ta sẽ thử cả 26 khóa để phá mã này. Bảng dưới đây minh họa phép thử vét cạn này, với n là độ dài đoạn mã “bị tóm” tính đến thời điểm tương ứng.

Shift	Decryption	N = 1	n = 2	n = 3	n = 4	n = 5
0	rdchx	0.060	0.070			
25	sediy	0.063	0.257	0.427	0.182	

24	tfejz	0.091	0.003			
23	ugfka	0.28	0.052			
22	vhglb	0.010				
21	wihmc	0.024	0.128			
20	xjind	0.002				
19	ykjoe	0,020				
18	zlkpf	0.001	0.001			
17	amlqg	0.082	0.072	0.004		
16	bnmrh	0.015				
15	consi	0.028	0.202	0.515	0.818	1
14	dpotj	0.043				
13	eqpuk	0.127	0.044			
12	frqvl	0.022	0.058			
11	gsrwm	0.020	0.015			
10	htsxn	0.061	0.052	0.046		
9	iutyo	0.070	0.001			
8	qvuzp	0.002				
7	kwvaq	0.008				
6	lxwbr	0.040				
5	myxcs	0.024	0.028			
4	nzydt	0.067	0.028			
3	oazeu	0.075	0.014			
2	pbafv	0.019				
1	qcbgw	0.001				

Phần sau đây sẽ trình bày một định nghĩa tương đối chặt chẽ về khái niệm bí mật tuyệt đối.

1.3.2. Khái niệm bí mật tuyệt đối

Qua ví dụ 1.15 ở trên, dễ thấy rằng khi độ dài đoạn mã nghe trộm tăng lên thì phân phối xác suất của tính khả thi của mỗi ứng cử viên bản rõ/khóa sẽ thay đổi liên tục: hầu hết các xác suất sẽ giảm và chỉ có một xác suất sẽ tăng (để trở thành 1 sau này). Điều này rõ ràng cho thấy tính không an toàn của mật mã. Ngược lại, nó cho một cảm nhận tạm thời về mật mã an toàn: phân phối xác suất của các ứng viên bản rõ phải thay đổi ít hoặc không thay đổi khi Eve thu nhận thêm các đoạn mã nghe trộm được. Vậy, khái niệm bí mật tuyệt đối (BMTĐ) có thể được định nghĩa như sau.

Trong hệ thống *đảm bảo bí mật tuyệt đối*, bản mã bị tiết lộ cho kẻ thù không hề đem lại một ý nghĩa nào cho phân tích tìm khóa phá mã. Sự kiện nghe trộm bản mã (có độ dài bất kỳ) sẽ không làm thay đổi phân phối xác suất ban đầu của plaintext.

Hay là, một hệ thống là có bí mật tuyệt đối nếu:

$$P(X) = P(X/Y) \quad \forall \text{ TIN } X \text{ VÀ MÃ } Y$$

Định lý Shannon. Trong hệ thống có BMTĐ, số lượng khóa có thể (độ lớn không gian khóa) phải lớn hơn hoặc bằng số lượng thông báo có thể (độ lớn không gian TIN).

Điều này cho thấy để đạt được BMTĐ thì khóa phải rất dài, do đó việc trao chuyển khóa giữa hai bên truyền tin sẽ làm cho hệ thống trở nên phi thực tế. Như vậy, nhìn chung chúng ta không thể đạt được bí mật tuyệt đối mà chỉ có thể có được các hệ thống với mức an toàn thực tế (Practical security) được cài đặt tùy theo giá trị của thông tin cần bảo vệ và thời gian sống của nó.

1.3.3. Đánh giá mức độ bảo mật của một cipher

Shannon đưa ra một khái niệm, *unicity distance*, để “đo” mức an toàn của một hệ mã: Unicity distance, ký hiệu N_0 , là độ dài tối thiểu của bản mã nghe trộm được để có thể xác định được khóa đúng duy nhất. Unicity distance có thể được tính theo công thức:

$$N_0 = \frac{\log_2 E}{d}$$

Trong đó d là *độ dư thừa* của ngôn ngữ sử dụng của TIN.

Ví dụ 1.16: Câu tốc ký sau đây thực tế có thể khôi phục được về dạng đầy đủ một cách duy nhất:

Mst ids cn b xprsd n fwr ltrs, bt th xprsn s mst nplsnt → Most ideas can be expressed in fewer letters, but the expression is most unpleasant.

Điều này chứng tỏ những chữ đã bị mất trong câu ban đầu là dư thừa về mặt biểu diễn thông tin (nhưng cần thiết để bảo đảm tính dễ hiểu, đọc nhanh).

Khái niệm *độ dư thừa* có thể được định nghĩa thông qua công thức:

$$d = R - r \text{ bits}$$

Trong đó R : *absolute rate* và r : *true rate* của ngôn ngữ.

R được định nghĩa như là số lượng bit được sử dụng để biểu thị một chữ cái trong bảng chữ với giả sử các chữ có tần suất xuất hiện như nhau:

$$R = \log_2 A \text{ bits}$$

với A là kích thước của bảng chữ.

Ví dụ 1.17: Đối với tiếng Anh ta có $R = \log_2 26 \approx 4.7$ bit.

Đại lượng *true rate* r được định nghĩa như là số lượng bit trung bình để biểu thị một chữ cái khi văn bản được biểu diễn ở dạng tối giản: xử lý theo kiểu tốc ký, gạt bỏ các chữ không cần thiết (hoặc áp dụng kỹ thuật nén trên cơ sở các thuộc tính thống kê của văn bản) mà vẫn không làm mất thông tin chuyển tải.

Ví dụ 1.18: Đối với văn bản tiếng Anh, tính trung bình, r nằm trong khoảng 1 – 1,5 bit.

Độ dư thừa có thể coi là một thước đo của tính cấu trúc và tính “dễ đoán” (predictability) của ngôn ngữ. Độ dư thừa cao hơn chứng tỏ tính cấu trúc và tính “dễ đoán” cao hơn. Một nguồn phát tin thực sự ngẫu nhiên sẽ không có dư thừa.

Trong tiếng Anh, độ dư thừa nằm trong khoảng từ 3.2 đến 3.7 bit (gây nên bởi sơ đồ tần suất ký tự “lỗi lôm” và các mẫu tự bộ 2-chữ, 3-chữ phổ biến).

Sử dụng Unicity distance ta có thể so sánh độ an toàn của các thuật toán mã hóa khác nhau.

Ví dụ 1.19: Với mã 1–bảng thế, ta quan sát thấy

$$E = |Z| = 26!$$

$$P(Z) = 1/26!$$

$$\log_2 E = \log_2(26!) \approx 88.4 \text{ bits}$$

$$N_0 \approx 88.4 / 3.7 \approx 23.9 \text{ ký tự}$$

Như vậy các MÃ chứa 24 ký tự trở lên sẽ có thể bị giải mã một cách duy nhất.

Ví dụ 1.20: Với mã one–time–pad:

X = không gian TIN = {tập hợp các đoạn văn bản tiếng Anh có độ dài k }

Z = không gian khóa = {tập các chuỗi chữ độ dài k trong bảng chữ cái tiếng Anh}

Giả thiết các khóa được chọn một cách ngẫu nhiên với xác suất đồng nhất:

$$N_0 = \log_2 E/d$$

$$E = 26^k \rightarrow \log_2(26^k) = k \log_2 26 \approx 4.7k$$

$$N_0 = (4.7k)/3.7 = 1.37k$$

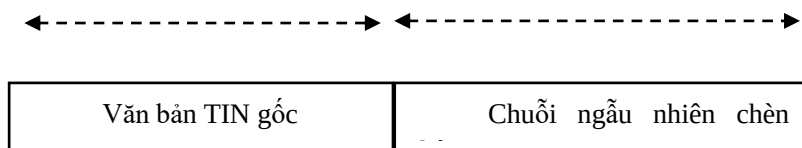
Do đó, thậm chí nếu E nghe trộm toàn bộ tất cả các chữ cái của đoạn MÃ, cô ta vẫn không thể giải phá mã (tìm được TIN tương ứng duy nhất).

Ta có thể “tăng” tính mật của một hệ mã cho trước bằng một trong các cách sau:

1. Tăng độ lớn không gian khóa.
2. Giảm tính dư thừa của ngôn ngữ văn bản TIN: tiền xử lý qua một bước thuật toán nén.

Chú ý: một thuật toán nén lý tưởng có thể đem lại độ dư thừa 0, do đó $N_0 \equiv 0$.

3. Có thể chèn thêm một đoạn văn bản ngẫu nhiên để “phẳng hóa” độ thị tần suất của văn bản TIN. Ta sẽ xét cụ thể biện pháp này dưới đây:



Công thức sau cho biết độ dư thừa của văn bản mới (sau khi chèn thêm chuỗi ký tự ngẫu nhiên):

$$\tilde{d} = \frac{M}{L + M} d$$

CÂU HỎI VÀ BÀI TẬP

1. Phân biệt các thuật ngữ cryptography, cryptanalysis và cryptology. “Khoa học mật mã” là tương ứng với thuật ngữ tiếng Anh nào?
2. Trong thời kỳ nào kỹ thuật mật mã chưa được coi là một ngành khoa học? Tại sao?
3. Hãy phân biệt các hệ biến đổi mã thông thường (Morse code, ASCII code) với các hệ mật mã.
4. Hãy phân tích ý nghĩa của Luật **Kerckhoffs** để thấy tại sao mật mã hiện đại không chấp nhận quan điểm cần che giấu thuật toán mật mã.
5. Phân tích những nhược điểm chính của nguyên lý hệ mật mã đối xứng (SKC).
6. Ưu điểm chính của mật mã khóa công khai (PKC) so với SKC?
7. Giải thích thuật ngữ *tấn công biết-bản-rõ* (*known-plaintext attack*) và lấy ví dụ những tình huống thực tế làm cơ sở cho hình thức tấn công này.
8. Tại sao hình thức *tấn công bản-rõ-chọn-sẵn* (*chosen-plaintext attack*) được xem là mạnh hơn so với *tấn công biết-bản-rõ*?
9. Khái niệm *bí mật tuyệt đối* (*perfect secrecy*) được gắn liền với mô hình tấn công nào? Tại sao?
10. Phân biệt *bảo mật chứng minh được* (*provable security*) và *bảo mật thực tiễn* (*practical security*).
11. Tìm số lượng khóa thực sự dùng được với mật mã nhân tính. Hãy lập luận chi tiết.
12. Hãy tìm (và đưa lập luận chi tiết) số khóa khả thi của mật mã affine.
13. Tại sao không thể nói mọi khóa của mật mã một-bảng-thể đều an toàn như nhau?
14. Tại sao ta không thể sử dụng quan hệ thứ tự trong cùng một nhóm tần suất trong phân tích giải mã? Giải thích qua ví dụ.

15. Tại sao nói quy luật tần suất không đồng đều chi phối mạnh mẽ hơn ở các từ có độ dài lớn hơn?
16. Hãy giải tới cùng mật mã trong ví dụ 1.8 và dịch nghĩa bản rõ sang tiếng Việt.
17. Hãy giải thích tại sao đồ thị tần suất của các mật mã đồng âm lại bằng phẳng và tại sao mã lại có dư thừa?
18. Hãy so sánh IC của một bản rõ M và IC của một mã ngẫu nhiên R có cùng độ dài. Lập luận để giải thích chặt chẽ.
19. Trong quá khứ đã có nhiều người muốn sử dụng One-time-pad với khóa chọn từ một quyển sách mà hai bên nhận và gửi đều có (mỗi lần mã lại chọn lại khóa). Như vậy có đảm bảo tính bí mật tuyệt đối?
20. Tại sao có thể nói mật mã one-time-pad là một trường hợp đặc biệt của mật mã Vigenere? Có thể nói gì về IC của mật mã one-time-pad?

Chương 2

MẬT MÃ KHỐI VÀ MẬT MÃ KHÓA ĐỐI XỨNG

Bắt đầu từ chương 2 chúng ta sẽ nghiên cứu các kiến thức của KHMM hiện đại. Chương này sẽ trình bày các khái niệm cơ sở trong mật mã khóa đối xứng theo quan điểm truyền thống. Mặc dù hiện nay hệ mật mã DES không còn là một chuẩn mật mã dùng phổ biến, nhưng nó vẫn có vai trò quan trọng trong việc làm quen và bắt đầu học tập các kiến thức cơ sở về mật mã. Nội dung chính của chương này như sau:

- Khái niệm và nguyên lý thiết kế cơ sở;
- Chuẩn mật mã DES (Data Encryption Standard);
- Các hệ mật mã đối xứng khác;
- Các chế độ mật mã khối.

2.1. KHAI NIỆM VÀ NGUYÊN LÝ THIẾT KẾ CƠ SỞ

Các hệ mật mã cổ điển được giới thiệu trong chương trước đều thuộc loại mật mã dòng (stream cipher), trong đó phép biến đổi mật mã thực hiện trên từng ký tự độc lập. Tuy nhiên, ngày nay được ưa chuộng sử dụng hơn là một kiểu mật mã khác – mật mã khối (block cipher) – trong đó từng khối nhiều ký tự được mã hóa cùng một lúc. Trong mật mã khối, các tham số quan trọng là kích thước (độ dài khối) và kích thước khóa. Các khái niệm này được minh họa qua ví dụ sau đây.

Ví dụ 2.1: Bảng sau đây biểu diễn một thuật toán mã hóa theo khối

key	000	001	010	011	100	101	110	111
0	001	111	110	000	100	010	101	011
1	001	110	111	100	011	010	000	101
2	001	000	100	101	110	111	010	011
3	100	101	110	111	000	001	010	011
4	101	110	100	010	011	001	011	111

Theo bảng này, dữ liệu plaintext 010100110111 sẽ được mã hóa thành:

010 100 110 111 → 111 011 000 101 theo key = 1

010 100 110 111 → 100 011 011 111 theo key = 4

Ở đây số lượng khóa là 5, do $2^2 < 5 < 2^3$ nên cần 3 bit để biểu diễn và lưu giữ khóa, tức là kích thước khóa là 3. Đồng thời kích thước khối cũng là 3.

Cũng qua ví dụ đơn giản này (chỉ có tính chất minh họa), ta thấy rằng nếu các tham số kích thước khối và khóa qua nhỏ thì mật mã rất dễ bị phá bằng các tấn công thông qua phân tích thống kê. Chẳng hạn trong ví dụ trên, nếu kẻ thù nhận được một khối mã ciphertext 001 thì nó có thể dễ dàng suy ra plaintext tương ứng chỉ có thể là 000 hoặc 101 (nhờ thống kê trên bảng biến đổi mã).

Vì vậy, ***các điều kiện cần cho mật mã khối an toàn*** là:

- Kích thước khối phải đủ lớn để chống lại các loại tấn công phá hoại bằng phương pháp thống kê. Tuy nhiên cần lưu ý rằng kích thước khối lớn sẽ làm thời gian trễ lớn.
- Không gian khóa phải đủ lớn (tức là chiều dài khóa phải đủ lớn) để chống lại tìm kiếm vét cạn. Tuy nhiên mặt khác, khóa cần phải đủ ngắn để việc làm khóa, phân phối và lưu trữ được hiệu quả.

Về các nguyên lý thiết kế mật mã khối, người ta đã ghi nhận hai nguyên tắc cơ sở sau để có bảo mật cao, đó là việc tạo ra confusion (tính hỗn loạn, rắc rối) và diffusion (tính khuếch tán).

Confusion (Hỗn loạn, rắc rối): Sự phụ thuộc của bản mã đối với bản rõ phải thực phức tạp để gây rắc rối, cảm giác hỗn loạn đối với kẻ thù có ý định phân tích tìm quy luật để phá mã. Quan hệ hàm số của mã–tín là phi tuyến (non-linear).

Diffusion (Khuếch tán): Làm khuếch tán những mẫu văn bản mang đặc tính thống kê (gây ra do dư thừa của ngôn ngữ) lẫn vào toàn bộ văn bản. Nhờ đó tạo ra khó khăn cho kẻ thù trong việc dò phá mã trên cơ sở thống kê các mẫu lặp lại cao. Sự thay đổi của một bit trong một khối bản rõ phải dẫn tới sự thay đổi hoàn toàn trong khối mã tạo ra.

Một cách đơn giản nhất, *confusion* có thể được thực hiện bằng phép thay thế (substitution) trong khi *diffusion* được tạo ra bằng các phép chuyển đổi chỗ (transposition/permutation) hay hoán vị. Toàn bộ sơ đồ biến đổi mật mã sẽ là một lưới các biến đổi thay thế – hoán vị (substitution–permutation network).

Ví dụ 2.2: Phép hoán vị cột: Để mã hóa “computer security”, ta viết lại thành nhiều hàng năm cột

c o m p u

t e r s e

c u r i t

y.

Mã tạo ra bằng cách viết lại theo cột: C T C Y O E U M R R P S I U E T

Bên cạnh các nguyên tắc tạo tính bảo mật nói trên, việc thiết kế mật mã khối cũng đề cao các nguyên tắc cài đặt hiệu quả:

Cài đặt cho phần mềm cần đảm bảo tính mềm dẻo và giá thành thấp.

Cài đặt cho phần cứng cần đảm bảo tốc độ cao và tính kinh tế.

Để đáp ứng tốt các nguyên lý thiết kế đã nêu trên, các thuật toán mật mã khối thường được tổ chức như một cấu trúc nhiều vòng lặp.

Khái niệm vòng lặp

Một cách phổ biến, các hệ mã khối thường được thiết kế theo cấu trúc nhiều vòng lặp với mỗi vòng lặp lại gọi thực hiện một hàm f cơ sở (nhưng với các tham số khác nhau). Theo đó, đầu vào của một vòng lặp là đầu ra của vòng lặp trước và một khóa con phát sinh từ khóa đầy đủ dựa trên một thuật toán lập lịch khóa (key scheduler), hay cũng gọi là thuật toán sinh khóa con.

Giải mã sẽ là một quá trình ngược, trong đó các khóa con sử dụng tại mỗi vòng lặp sẽ được lập lịch để sử dụng theo thứ tự ngược.

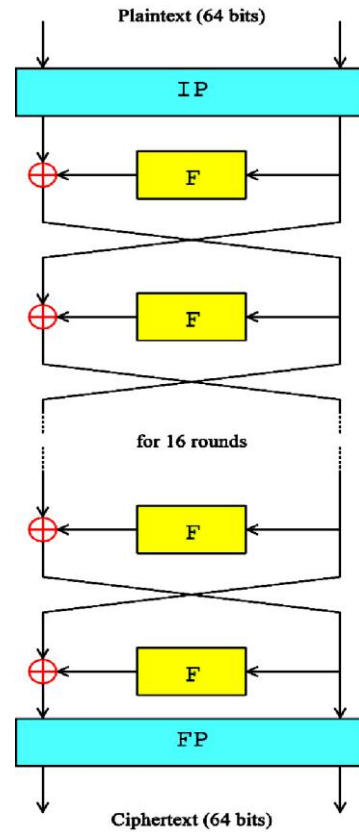
Thông thường, hàm cơ sở vòng lặp f được thiết kế có một tính chất đặc biệt là tính đối hợp hàm (involution), tức là nó bằng hàm ngược của nó: $f = f^{-1}$ hay là $f(f(x)) = x$.

Ví dụ 2.3: Ta xét phép biến đổi f với miền xác định: $x \in \{\text{tập các chuỗi nhị phân độ dài 3}\}$

$$f = \begin{bmatrix} 123 \\ 213 \end{bmatrix} \text{ (bit thứ nhất và thứ hai đổi chỗ cho nhau, bit thứ ba giữ nguyên).}$$

Như thế ta có f là một hàm có tính đối hợp, chẳng hạn cụ thể là: $f(101) = 011$; từ đó $f(f(101)) = 101$.

Chúng ta sẽ tìm hiểu chi tiết một hệ mã khối điển hình, đó là chuẩn mật mã DES (Data Encryption Standard); chuẩn này ra đời vào năm 1977 và đã thống trị ứng dụng mật mã suốt hai thập kỷ sau đó. Tuy nhiên chuẩn mật mã này đã trở nên lạc hậu, kém an toàn và được thay thế bởi chuẩn mới AES (Advanced Encryption Standard).



Hình 2.1. Sơ đồ minh họa một cấu trúc 16 vòng lặp, với đầu vào và ra đều có kích thước 64 bit (Nguồn: Wikipedia). Có hai khối hoán vị đầu và cuối (IP và FP). Hàm F cơ sở chỉ nhận đầu vào 32 bit, nhưng tác động của nó sẽ rộng khắp qua chỉ hai vòng nhờ sự hoán vị hai nửa trái và phải.

2.2. CHUẨN MẬT MÃ DES

2.2.1. Lịch sử của DES

Vào những năm đầu thập kỷ 70, nhu cầu có một chuẩn chung về thuật toán mật mã đã trở nên rõ ràng. Các lý do chính là:

- Sự phát triển của công nghệ thông tin và của nhu cầu an toàn & bảo mật thông tin: sự ra đời của các mạng máy tính tiền thân của Internet đã cho phép khả năng hợp tác và liên lạc số hóa giữa nhiều công ty, tổ chức trong các dự án lớn của chính phủ Mỹ.

- Các thuật toán "cây nhà lá vườn" (ad hoc) không thể đảm bảo được tính tin cậy đòi hỏi cao.

- Các thiết bị khác nhau đòi hỏi sự trao đổi thông tin mật mã thống nhất, chuẩn.

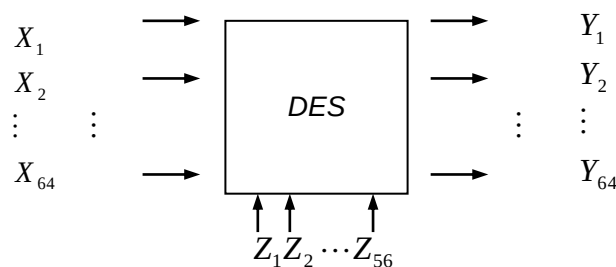
Một chuẩn chung cần thiết phải có với các thuộc tính như:

1. Bảo mật ở mức cao;
2. Thuật toán được đặc tả và công khai hoàn toàn, tức là tính bảo mật không được phép dựa trên những phần che giấu đặc biệt của thuật toán;
3. Việc cài đặt phải dễ dàng để đem lại tính kinh tế;
4. Phải mềm dẻo để áp dụng được cho muôn vàn nhu cầu ứng dụng.

Năm 1973, Cục quản lý các chuẩn quốc gia của Mỹ đã có văn bản cổ động cho việc tạo lập các hệ mật mã chuẩn ở cơ quan đăng ký liên bang của Mỹ. Điều này làm cơ sở cho sự công bố của Cục An ninh Quốc gia Mỹ (NSA) về Data Encryption Standard, viết tắt là DES vào năm 1977. Thực chất, DES được phát triển bởi IBM như là sự sửa đổi của một hệ mã trước kia được biết với cái tên Lucifer. Trong khoảng hai thập kỷ tiếp theo, DES là hệ mã được dùng rộng rãi nhất và cũng là gây ra nhiều nghi ngờ, tranh cãi trong lĩnh vực này: xung quanh các nguyên tắc thiết kế đảm bảo tính mật, chiều dài khóa tương đối ngắn và khả năng NSA còn che giấu cửa sau (backdoor) để có thể bẻ khóa, phá mã ít tốn kém hơn thông thường.

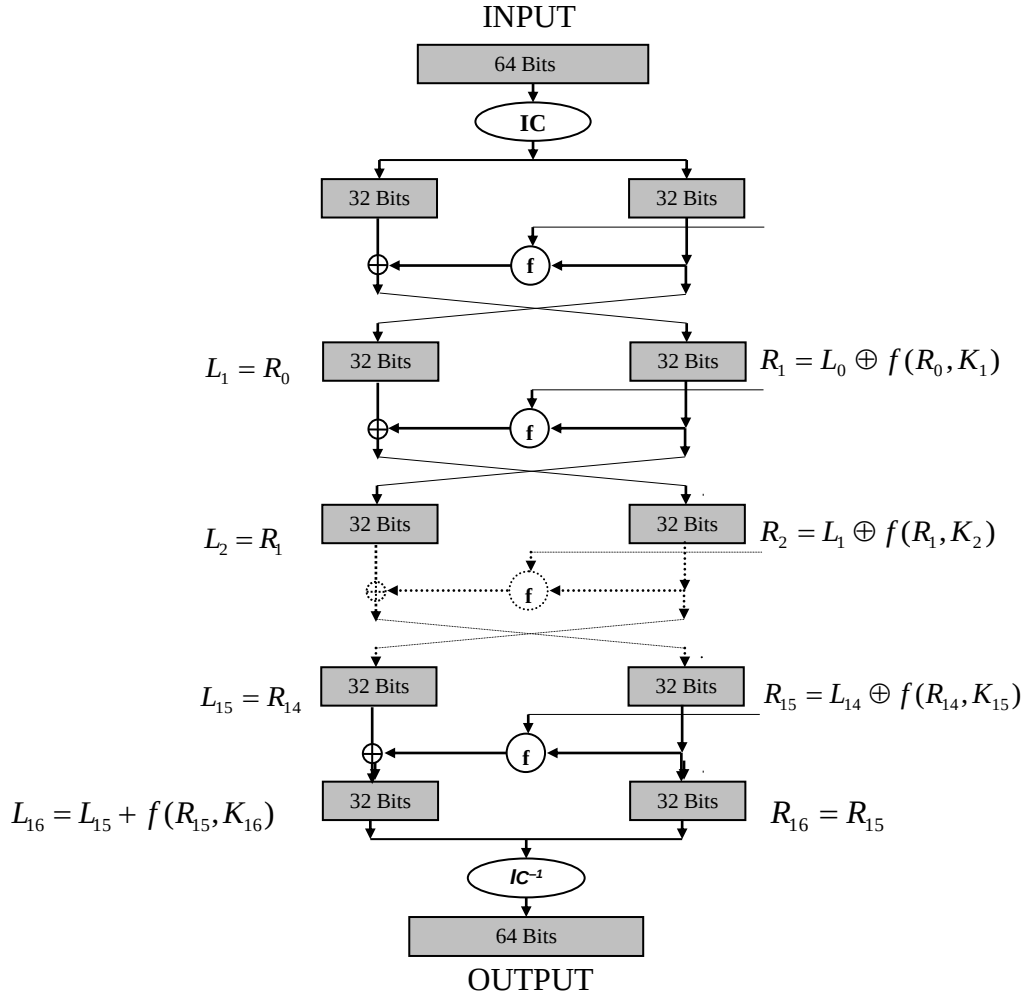
2.2.2. Thuật toán và lưu đồ hoạt động của DES

Các hình vẽ sau cung cấp sơ đồ khái quát và chi tiết của thuật toán sinh mã trong DES.



Hình 2.2. Sơ đồ cơ bản của DES: đầu vào của DES là khối độ dài 64 bit, đầu ra 64 bit và khóa là 56 bit.

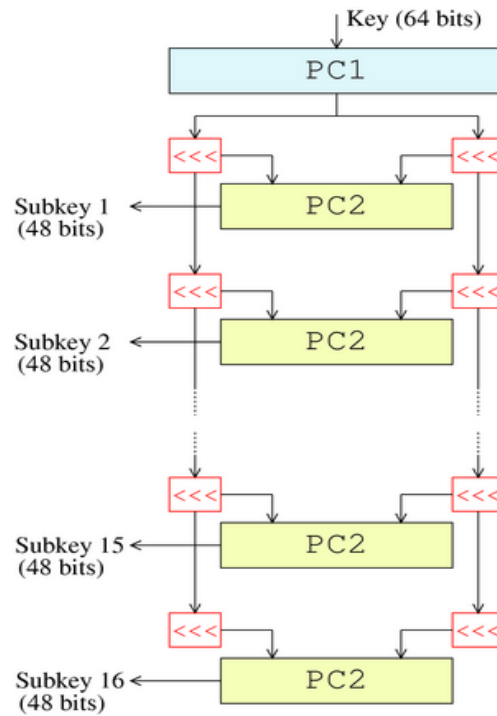
Sơ đồ hình 2.3 cho thấy DES được cấu tạo bởi 16 bước lặp với bước lặp cơ sở gọi hàm chuyển đổi phi tuyến f ; 16 bước lặp này được kẹp vào giữa hai tác tử giao hoán IP và IP^{-1} . Hai tác tử này không có ý nghĩa gì về mặt bảo mật mà hoàn toàn nhằm tạo điều kiện cho việc cài đặt phần cứng, "chip hóa" thuật toán DES. Hàm cơ sở f là nguồn gốc của sức mạnh bảo mật trong thuật toán DES này. Sự lặp lại nhiều lần các bước lặp với tác dụng của f là nhằm tăng cường tính confusion và diffusion đã có trong f .



Hình 2.3. Sơ đồ giải thuật sinh mã DES với cấu trúc 16 vòng lặp

Thuật toán sinh khóa con

16 vòng lặp của DES cùng gọi thực hiện f nhưng với các tham số khóa khác nhau. Tất cả 16 khóa khác nhau này, được gọi là khóa con, cùng sinh ra từ khóa chính của DES bằng một thuật toán sinh khóa con. Trong thuật toán sinh khóa con này (lập lịch khóa), khóa chính K , 64 bit, đi qua 16 bước biến đổi, tại mỗi bước này một khóa con được sinh ra với độ dài 48 bit. Hình 2.4 thể hiện lưu đồ thuật toán.



Hình 2.4. Sơ đồ thuật toán sinh khóa con (Key Scheduler) – Nguồn: Wikipedia

Qua sơ đồ thuật toán sinh khóa con có thể thấy rằng thực sự chỉ có 56 bit của khóa chính được sử dụng, 8 bit còn lại là mã kiểm tra chẵn lẻ (parity bits) và bị lọc ra ở biến đổi PC1. Các bộ biến đổi PC1 và PC2 chỉ đơn giản là các bộ vừa chọn lọc vừa hoán vị (PC = permuted choice = lựa chọn có hoán vị). Các biến đổi R1 và R2 (left rotate 1 bit và 2 bit) tương ứng là các phép đẩy bit trái một và hai vị trí.

Mỗi vòng lặp của DES thực hiện trên cơ sở công thức sau:

$$(L_i, R_i) = (R_{i-1}, L_{i-1} \oplus f(R_{i-1}, K_i))$$

trong đó, (L_i, R_i) là hai nửa trái và phải thu được từ biến đổi của vòng lặp thứ i .

Ta cũng có thể viết lại:

$$(L_i, R_i) = T \circ F(R_{i-1}, K_i)$$

Trong đó F_i là phép thay thế L_{i-1} bằng $L_{i-1} \oplus f(R_{i-1}, K_i)$, còn T là phép đổi chỗ hai thành phần L và R . Tức là mỗi biến đổi vòng lặp của DES có thể coi là một tích hàm số của F và T (trừ vòng cuối cùng không có T).

Ta có thể viết lại toàn bộ *thuật toán sinh mã DES* dưới dạng công thức tích hàm số như sau:

$$DES = (IP)^{-1} \circ F_{16} \circ T \circ F_{15} \circ T \circ \dots \circ F_2 \circ T \circ F_1 \circ (IP)$$

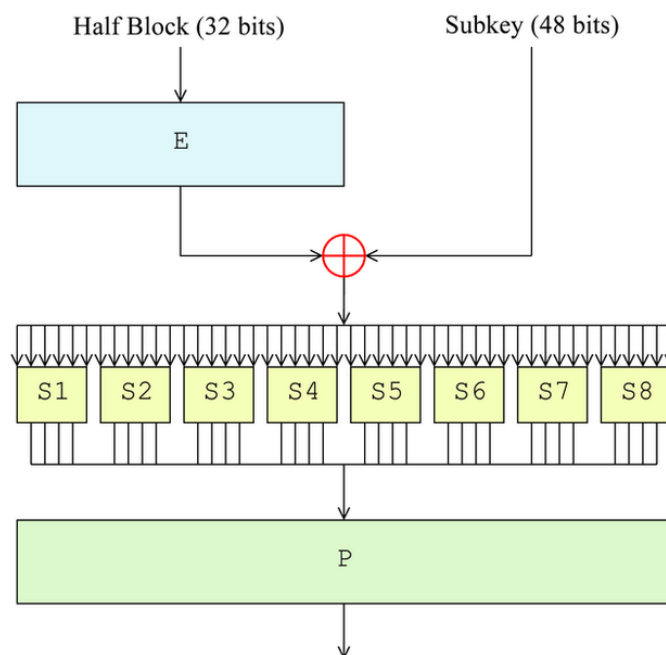
Thuật toán giải mã DES được xây dựng giống hệt như thuật toán sinh mã nhưng có các khóa con được sử dụng theo thứ tự ngược lại, tức là dùng khóa K_{16} cho vòng lặp 1, khóa K_{15} cho vòng lặp 2... Vì vậy, thuật toán giải mã có thể được viết lại dưới dạng công thức sau:

$$DES^{-1} = (IP)^{-1} \circ F_{16} \circ T \circ F_{15} \circ T \circ \dots \circ F_2 \circ T \circ F_1 \circ (IP)$$

Bây giờ chú ý rằng mỗi hàm T hoặc F_i đều là các hàm có tính chất đối hợp ($f = f^{-1}$, hay $f(f(x)) = x$). Do đó nếu ta thực hiện phép tích hàm $DES^{-1} \circ DES$ hay $DES \circ DES^{-1}$ thì sẽ thu được phép đồng nhất. Điều đó giải thích tại sao thuật toán giải mã lại giống hệt như sinh mã chỉ có khác về thứ tự trong chuỗi khóa con.

Cấu trúc cụ thể hàm f

Sơ đồ biến đổi cụ thể của hàm f được minh họa trong hình 2.5. Trước hết, 32 bit của thành phần R_{i-1} được mở rộng thành 48 bit thông qua biến đổi E (expansion: mở rộng với sự lặp lại một số bit) rồi đem XOR với 48 bit của khóa K_i . Tiếp theo, 48 bit kết quả sẽ được phân thành 8 nhóm 6 bit. Mỗi nhóm này sẽ đi vào một biến đổi đặc biệt gọi là biến đổi S-box (có 8 S-box khác nhau ứng với mỗi nhóm 6 bit) và cho ra kết quả là 8 nhóm 4 bit. Từ đó, 32 bit hợp thành (sau khi qua 8 S-box khác nhau) sẽ được hoán vị lại theo hàm hoán vị P để đưa ra kết quả cuối cùng của hàm f (tức nhân của F_i).



Hình 2.5. Cấu trúc của biến đổi hàm f , bước lặp cơ sở của DES. Nguồn: Wikipedia

★ Cấu trúc của các S-Box

Như ta biết mỗi một trong tám nhóm 6 bit sẽ đi vào mỗi trong tám bộ biến đổi $S_1, S_2, \dots, S_8$. Mỗi S-box bao gồm bốn bảng biến đổi dòng, thực chất là một biến đổi hoán vị cho 16 tổ hợp của 4 bit. Trong 6 bit đầu vào thì hai bit ngoài cùng (bit 1 và 6) được dùng để chỉ định một trong bốn bảng biến đổi dòng này; vì thế chúng được gọi là các bit điều khiển trái và phải (CL và CR). Còn lại 4 bit chính (các bit 2–5) của nhóm 6 bit đầu vào sẽ là tổ hợp 4 bit bị biến đổi.

S_5	Middle 4 bits of input															
	0000	0001	0010	0011	0100	0101	0110	0111	1000	1001	1010	1011	1100	1101	1110	1111
Outer bits	00	0010	1100	0100	0001	0111	1010	1011	0110	1000	0101	0011	1111	1101	0000	1110 1001
	01	1110	1011	0010	1100	0100	0111	1101	0001	0101	0000	1111	1010	0011	1001	1000 0110
	10	0100	0010	0001	1011	1010	1101	0111	1000	1111	1001	1100	0101	0110	0011	0000 1110
	11	1011	1000	1100	0111	0001	1110	0010	1101	0110	1111	0000	1001	1010	0100	0101 0011

Hình 2.6. Bảng biến đổi S_5 : đầu vào 6 bits 011011 sẽ được biến đổi thành 1001 (ô vàng)

★ Các thuộc tính của S-Box

Các nguyên tắc thiết kế của 8 S-box được đưa vào lớp thông tin mật "Classified information" ở Mỹ. Mặc dù vậy, NSA đã tiết lộ ba thuộc tính của S-boxes, những thuộc tính này bảo đảm tính confusion & diffusion của thuật toán.

1. Các bit vào (output bit) luôn phụ thuộc không tuyến tính vào các bit ra (input bit).
2. Sửa đổi ở một bit vào làm thay đổi ít nhất là hai bit ra.

3. Khi một bit vào được giữ cố định và 5 bit còn lại cho thay đổi thì S-boxes thể hiện một tính chất được gọi là "phân bố đồng nhất" (uniform distribution): so sánh số lượng bit số 0 và 1 ở các đầu ra luôn ở mức cân bằng. Tính chất này khiến cho việc áp dụng phân tích theo lý thuyết thống kê để tìm cách phá S-boxes là vô ích.

Rõ ràng, 3 tính chất này đảm bảo tốt confusion & diffusion. Thực tế, sau tám vòng lặp, tất cả các bit ra của DES sẽ chịu ảnh hưởng của tất cả các bit vào và tất cả các bit của khóa. Hơn nữa sự phụ thuộc này là rất phức tạp. Tuy nhiên, sau này một số tấn công mới đã được đề xuất và cho thấy tám vòng lặp này là chưa đủ để bảo mật (điều này cho thấy NSA đã biết trước các dạng tấn công này nên mới quy định số vòng lặp là 16 ngay từ đầu).

Chính cấu tạo của S-box đã gây tranh luận mạnh mẽ trong các thập kỷ 70 – 90 về khả năng cơ quan NSA (National Security Agency), Mỹ, vẫn còn che giấu các một số đặc tính của S-box hay cài bên trong những cửa bẫy (trapdoor) mà qua đó họ có thể dễ dàng phá giải mã hơn người bình thường (biết các bí mật này có thể gián lược không gian khóa 2^{56} để tìm kiếm vết cạm nhanh hơn). Sự phát hiện sau đó của các tấn công mới, rất mạnh như tấn công vi phân, đã củng cố sự nghi ngờ của giới khoa học.

★ 2.2.3 Các điểm yếu của DES

1. Tính bù

Ký hiệu $\bar{u}$ là phần bù của u (ví dụ 0100101 và 1011010 là bù của nhau) thì DES có tính chất sau:

$$y = \text{DES}_z(x) \Rightarrow \bar{y} = \text{DES}_{\bar{z}}(\bar{x})$$

Cho nên nếu biết MÃ y được mã hóa từ TIN x với khóa z thì ta suy ra $\bar{y}$ được mã hóa từ TIN $\bar{x}$ với khóa $\bar{z}$. Tính chất này chính là một điểm yếu của DES bởi vì nhờ đó kẻ địch có thể loại trừ một nửa số khóa cần phải thử khi tiến hành phép thử–giải mã theo kiểu tìm kiếm vét cạn không gian khóa.

2. Khóa yếu

Các khóa yếu là các khóa mà theo thuật toán sinh khóa con thì tất cả 16 khóa con đều như nhau

$$Z_1 = Z_2 = Z_3 = \dots = Z_{15} = Z_{16}$$

điều đó khiến cho phép sinh mã và giải mã đối với các khóa yếu này là giống hệt nhau

$$\text{DES}_z = \text{DES}_{\bar{z}}^{-1}$$

Có tất cả bốn khóa yếu như sau:

- 1) [00000001 00000001 ... 00000001]
- 2) [11111110 11111110 ... 11111110]
- 3) [11100000 11100000 11100000 11100000
11110001 11110001 11110001 11110001]
- 4) [00011111 00011111 00011111 00011111
00001110 00001110 00001110 00001110]

Đồng thời có 10 khóa yếu với thuộc tính là tồn tại Z, Z' sao cho:

$$\text{DES}_{\bar{z}}^{-1} = \text{DES}_{z'} \text{ hay là } \text{DES}_{\bar{z}'}^{-1} = \text{DES}_z$$

2.2.4. Tấn công bằng phương pháp vét cạn (hay là brute-force attack)

DES có $2^{56} = 10^{17}$ khóa. Nếu như biết một cặp plaintext–ciphertext thì chúng ta có thể thử tất cả 10^{17} khả năng này để tìm ra khóa cho kết quả khớp. Giả sử như một phép thử mất khoảng 10^{-6} s (trên một máy PC thông thường), thì chúng ta sẽ thử mất 10^{11} s tức là 7300 năm.

Nhưng nhớ rằng đây mới chỉ là sử dụng các máy tính thông thường, còn có các máy tính được chế tạo theo nguyên lý xử lý song song. Chẳng hạn nếu như làm được một thiết bị với 10^7 con chip mật mã DES chạy song song thì bây giờ mỗi con chip chỉ phải chịu trách nhiệm tính toán với 10^{10} phép thử. Chip mã DES ngày nay có thể

xử lý tới tốc độ là 4.5×10^7 bits/s tức là có thể làm được hơn 10^5 phép mã DES trong một giây.

Diffie và Hellman (1977) đã ước lượng rằng có thể chế được một máy tính chuyên dụng để vét cạn không gian khóa DES trong 1/2 ngày với cái giá cho chiếc máy này là 20 triệu đô la. Cái giá này được tính toán lại và giảm xuống \$200,000 vào năm 1987. Vì vậy, DES đã bị phê bình ngay từ khi ra đời vì có kích thước khóa quá ngắn.

Hiện nay đã có những thiết kế cụ thể cho loại máy tính chuyên dụng phá khóa này dựa trên kỹ thuật xử lý song song tiên tiến và cho biết một thiết bị kiểu này có giá khoảng \$10,000 có thể cho kết quả trong 1 ngày.

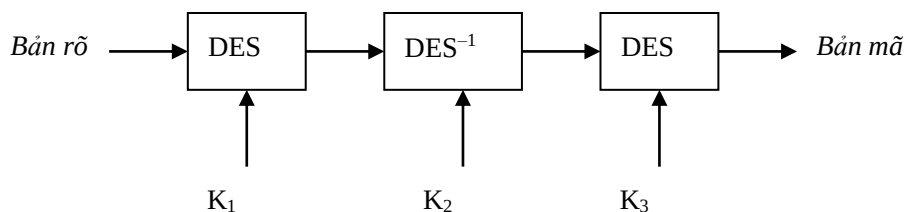
Sau đây là một đoạn trích, tham khảo từ nguồn Wikipedia (theo từ khóa DES):

In academia, various proposals for a DES-cracking machine were advanced. In 1977, Diffie and Hellman proposed a machine costing an estimated US\$20 million which could find a DES key in a single day. By 1993, Wiener had proposed a key-search machine costing US\$1 million which would find a key within 7 hours. However, none of these early proposals were ever implemented—or, at least, no implementations were publicly acknowledged. The vulnerability of DES was practically demonstrated in the late 1990s. In 1997, RSA Security sponsored a series of contests, offering a \$10,000 prize to the first team that broke a message encrypted with DES for the contest. That contest was won by the DESHALL Project, led by Rocke Verser, Matt Curtin, and Justin Dolske, using idle cycles of thousands of computers across the Internet. The feasibility of cracking DES quickly was demonstrated in 1998 when a custom DES-cracker was built by the Electronic Frontier Foundation (EFF), a cyberspace civil rights group, at the cost of approximately US\$250,000 (see EFF DES cracker). Their motivation was to show that DES was breakable in practice as well as in theory: "*There are many people who will not believe a truth until they can see it with their own eyes. Showing them a physical machine that can crack DES in a few days is the only way to convince some people that they really cannot trust their security to DES.*" The machine brute-forced a key in a little more than 2 days search.

★2.2.5. Tăng kích thước khóa của DES

Nếu như ta dùng nhiều khối DES nối tiếp thì có thể làm tăng kích thước của khóa. Tuy nhiên chú ý rằng nếu nối hai khối DES với hai khóa khác nhau (thuật toán 2-DES) thì không vì thế kích thước khóa của cả hệ thống được tăng gấp đôi thành $56 * 2 = 112$ bit mà chỉ là 57 bit.

Sơ đồ 3-DES dưới đây, trái lại, thực sự cung cấp một hệ mã với độ dài khóa là 112 bit.



Hình 2.7. Sơ đồ 3-DES (Triple-DES)

★2.2.6. Các dạng tấn công khác

Differential Cryptanalysis. Được công bố lần đầu bởi E. Biham và A. Shamir vào cuối những năm 80 (thế kỷ trước), tuy nhiên thực tế đã được biết đến từ lâu nhưng không công bố bởi IBM và NSA (Cục An ninh Quốc gia Mỹ). Để phá được DES với đầy đủ 16 vòng lặp, tấn công này cần tới 2^{49} bản rõ chọn trước (chosen plaintext). Để có được khối lượng bản rõ này là không thể xảy ra trên thực tế, điều đó cũng cho thấy là DES đã được thiết kế ban đầu để tránh được tấn công này.

Linear Cryptanalysis. Tấn công này được phát hiện bởi Matsui vào năm 1994, và cần 2^{43} bản rõ chọn trước.

2.3. CÁC HỆ MẬT MÃ KHỐI KHÁC

2.3.1. Các mật mã khối khác (cho đến năm 1999)

Qua thời gian, có nhiều thuật toán mật mã khối khác nhau được đề xuất bởi cộng đồng khoa học mật mã như FEAL (-4, -8, -N, -NX), NewDES, LOKI91, Blowfish, RC2, MMB, IDEA... Tuy nhiên, khá nhiều trong số đó đã bị phá giải hoặc chỉ ra có những điểm yếu nhất định. Điều đó chứng tỏ đề xuất thuật toán mã khối tốt có thể thay thế được DES không phải là đơn giản.

Trong số nói trên, IDEA (1990) có thể được xem là thuật toán có độ an toàn cao nhất, cho đến giờ vẫn chưa có một công bố nào nói lên một điểm yếu đáng kể nào của IDEA, mặc dù kể từ năm 1990 đã có nhiều loại tấn công rất mạnh được sử dụng để thử phá giải. IDEA chính là một trong các thuật toán được dùng trong PGP (Pretty Good Privacy) – một giải pháp bảo mật không thương mại gần như duy nhất cho phép các người dùng trên Internet sử dụng cho các nhu cầu thỏa mãn bí mật riêng như e-mail.

IDEA làm việc với dữ liệu khối 64 bit nhưng với khóa 128 bit nên việc thay thế sử dụng IDEA cho DES là một khó khăn lớn.

2.3.2. Mật mã AES

Vào năm 2000, cơ quan quản lý về chuẩn và công nghệ của Mỹ, NIST (National Institute of Standard and Technology), đã tổ chức một cuộc thi để chọn một hệ mật mã mới thay thế cho DES. Hệ mã Rijndael đã được chọn và được công bố (2002) như là

chuẩn mật mã mới thay thế cho DES, với tên gọi là Advanced Encryption Standard (AES). Vào đến vòng trong còn có các ứng viên khác là RC6, Serpent, MARS và Twofish. Hệ mã này được phát triển bởi hai nhà khoa học Bỉ, Joan Daemen và Vincent Rijmen (vì vậy tên gọi Rijndael được tạo ra từ việc ghép tiền tố tên họ hai ông).

AES được xây dựng trên nguyên lý thiết kế *lưới giao hoán – thay thế* (substitution–permutation network). Đây là một hệ mã có tốc độ tốt trong cả cài đặt phần mềm cũng như phần cứng. Khác với DES, AES không theo mẫu thiết kế mạng Feistel. Thay vào đó các thao tác cơ bản được thực hiện trên các khối ma trận dữ liệu 4×4 (bytes), được gọi là các trạng thái (state). Số vòng lặp của AES là một tham số xác định trên cơ sở kích thước khóa: 10 vòng lặp cho khóa 128 bit, 12 cho 192 bit, 14 cho 256 bit.

Giáo trình này sẽ không đi sâu tìm hiểu về AES. Sinh viên được khuyến khích tìm đọc thêm từ các tài liệu tham khảo về AES.

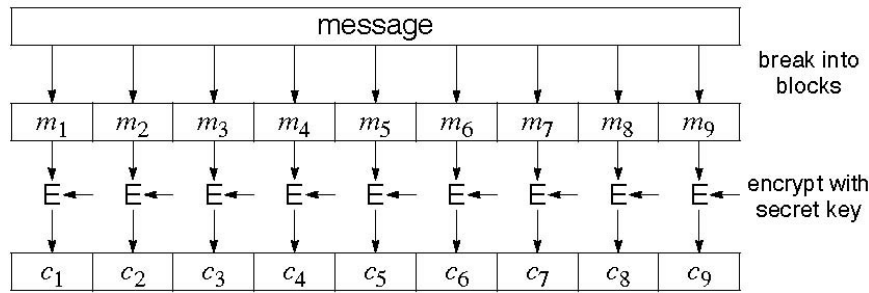
2.4. CÁC CHẾ ĐỘ SỬ DỤNG MÃ KHỐI

Thuật toán mã khối có đầu vào và đầu ra là các khối có độ dài xác định (như ở DES là 64 bit). Để mã hóa một dữ liệu có độ dài tùy ý thì ta phải cắt dữ liệu thành nhiều khối đơn vị và áp dụng thuật toán mã nhiều lần, rồi sau sẽ kết hợp các khối dữ liệu thu được theo một sơ đồ nào đó. Có nhiều loại sơ đồ, hay còn gọi là chế độ mật mã khác nhau, với ưu nhược điểm khác nhau và được áp dụng cho các nhu cầu khác nhau. Sau đây là một số chế độ hay dùng.

2.4.1. Chế độ bảng tra mã điện tử (Electronic code book – ECB)

Trong chế độ này, các khối được tạo mật mã riêng biệt, độc lập. Do đó, những khối tin giống nhau sẽ được mã hóa thành những khối mã giống nhau. Điều này trở nên nguy hiểm, tạo miếng đất màu mỡ cho kẻ địch vận dụng tấn công replay cũng như thao tác biên tập theo khối. Kẻ thù có thể nghe trộm và tìm cách thu thập các mẫu tin – mã phổ biến, sau đó cắt ghép và trộn lẫn để tạo ra các bản mã giả mã bên nhận không phát hiện được. Ví dụ: nếu ECB được sử dụng trong truyền tin mật trong giao dịch ngân hàng, kẻ địch có thể tấn công làm giả thông báo, lệnh chuyển tài khoản.

Nhược điểm nói trên khiến cho việc truyền tin mật theo chế độ mã này là không có lợi, tuy nhiên chế độ này thường được dùng trong mã hóa thông tin lưu trữ, ví dụ như các cơ sở dữ liệu vì nó cho phép từng đơn vị dữ liệu được mã hóa độc lập và do đó có thể cập nhật thay đổi dễ dàng từng phần mà không động chạm đến các phần khác của cơ sở dữ liệu.



Hình 2.8. Sơ đồ chế độ mật mã ECB. Nguồn: [19]

2.4.2. Chế độ mã móc xích (Cipher Block Chaining – CBC)

Trong chế độ này, mỗi khối tin trước khi được mã hóa thì được XOR với khối mã sinh ra từ bước trước đó.

$$X_1 = X_1' \oplus IV$$

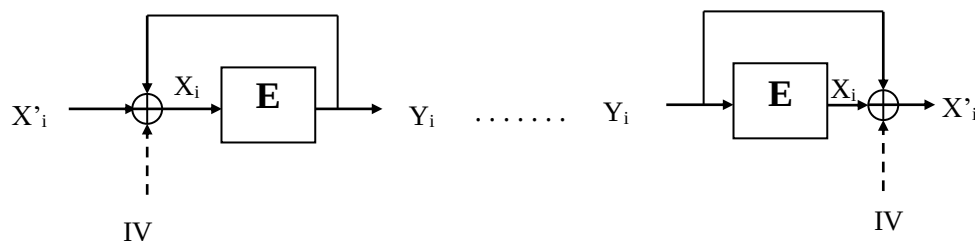
$$X_2 = X_2' \oplus Y_1$$

...

$$X_i = X_i' \oplus Y_{i-1}$$

Như vậy, các khối mã đều phụ thuộc rất chặt vào nhau theo kiểu “móc xích”. Cũng qua đó có thể thấy rằng CBC sẽ tạo ra các khối bản mã khác nhau khi các khối tin đưa vào là giống nhau tức là che giấu được các mẫu tin – mã phổ biến khỏi sự theo dõi của kẻ thù, chặn đứng khả năng phá hoại bằng tấn công replay và biên tập nói trên.

Tại bước đầu tiên, khi chưa có khối mã sinh ra từ bước trước, khối tin đầu sẽ được XOR với một vecto khởi đầu, chọn ngẫu nhiên, ký hiệu là IV (initial vector).



Hình 2.9. Sơ đồ chế độ mật mã CBC

Tính chất phụ thuộc lẫn nhau của các khối bản mã còn đem lại một ưu thế nữa là ngăn chặn kẻ thù sửa đổi bất kỳ phần nào của mã truyền tin, vì dù chỉ thay đổi 1 bit trên mã cũng làm ảnh hưởng đến toàn bộ thông tin được giải mã từ đó, đến mức người nhận có thể phát hiện được dễ dàng do đoạn thông tin giải mã sẽ bị hoàn toàn vô nghĩa.

Tuy nhiên, tính chất đó cũng đem lại một mối hại là nếu như mã truyền đi bị sai một ít do nhiễu thì giải mã sẽ bị ảnh hưởng lan truyền nhiều, dẫn đến phải phát lại. Ngoài

Liệu có tồn tại một cơ chế tấn công khác, thông minh hơn loại đã áp dụng cho ECB, để phá mã hoặc lợi dụng CBC? Lý luận về sự phụ thuộc móc xích mới chỉ cho ta một cảm giác an toàn chứ chưa phải là một chứng minh chặt chẽ. Tuy nhiên, tính an toàn trong truyền tin mật của chế CBC đã được chứng minh chặt chẽ bằng phương pháp toán học.

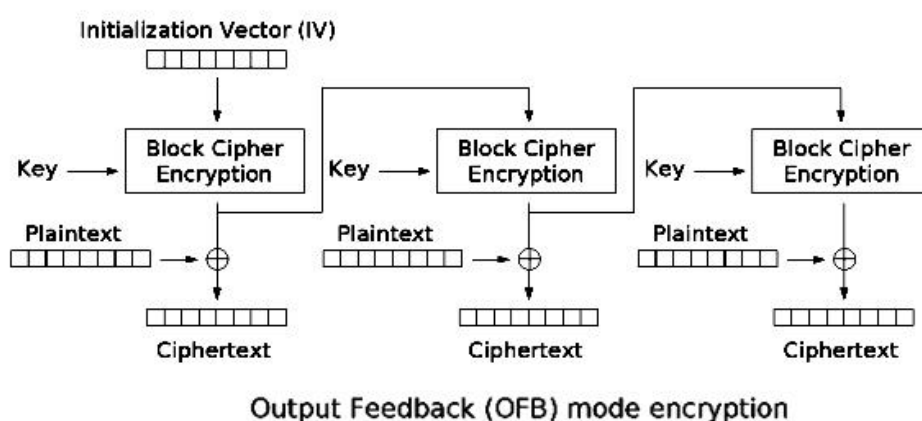
Với một số ứng dụng thời gian thực yêu cầu dòng dữ liệu truyền đến phải liên tục hơn là gián đoạn (như là chuỗi ký tự truyền giữa host và terminal phải tạo thành dòng ký tự liên tục). Do đó các chế độ mật mã khối xử lý và truyền theo từng khối một trở nên không thích hợp; các mã stream cipher với đơn vị xử lý là ký tự – khối 8 bit sẽ thích hợp hơn với dạng ứng dụng này.

Như vậy, có thể thấy rằng thuật toán mã khối được thực hiện như một hàm sinh các số giả ngẫu nhiên k-bit, các giá trị này lại được XOR với các phần tử k-bit tin lấy vào để tạo ra mã truyền đi.

64

2.4.4. Chế độ mật mã kết quả phản hồi (Output Feedback Mode – OFB)

Chế độ này cũng khá gần với hai chế độ trên đây, nhưng các phép XOR để tạo ra khối ciphertext là độc lập riêng rẽ, chứ không có sự phụ thuộc (móc xích) như trước. Các khối plaintext được XOR với các đầu ra – output – của các hàm sinh mã (thuật toán mật mã khối) mà riêng các phần tử output của hàm mã hóa này là vẫn phụ thuộc móc xích (nên được gọi là output feedback). Tuy nhiên chuỗi móc xích này có thể được thực hiện off-line thông qua tiền xử lý, trước khi thực sự có thông tin văn bản cần gửi đi. Chính vì vậy khả năng thời gian tính toán có thể được rút ngắn nhiều. Ngoài ra, chế độ này cũng cho phép mã khối nhỏ, như stream cipher, giống như với chế độ CFB vậy.



Hình 2.11. Sơ đồ chế độ mật mã OFB. Nguồn: [19]

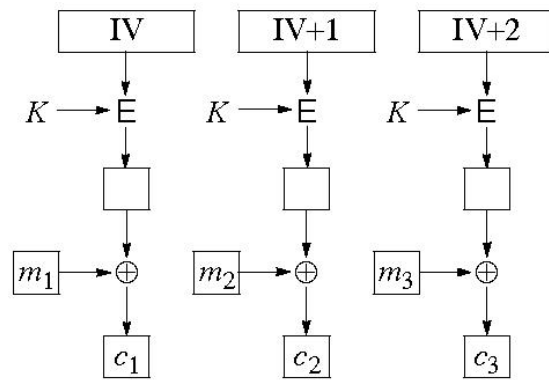
2.4.5. Chế độ mật mã con đếm (Counter mode – CTR)

Đây là chế độ mật mã mới được phát minh không lâu lắm (2000) và được cho là ưu tú nhất. Sơ đồ của nó đơn giản một cách đáng ngạc nhiên. Sự móc xích (feedback) giữa các khối đã được loại trừ hoàn toàn, làm cho CTR có những hiệu năng tính toán cao đáng mong ước:

- Có thể xử lý song song dễ dàng vì các khối tính toán hoàn toàn độc lập; ngoài ra cũng cho phép tiền xử lý để tính toán trước chuỗi phần tử output của hàm sinh mã (chẳng qua là chuỗi mã hóa của dãy số tự nhiên liên tiếp từ giá trị IV ban đầu).

- Không có sự phụ thuộc lẫn nhau nên có thể dùng vào mã hóa dữ liệu lưu trữ giống như với ECB: cho phép truy nhập ngẫu nhiên (random access) thay vì truy nhập tuần tự như với CBC chẳng hạn.

Mặc dù có sơ đồ tính toán rất đơn giản, tính an toàn của chế độ này đã được chứng minh đầy đủ bằng công cụ toán học hình thức, trên cơ sở thông qua so sánh với mật mã one-time-pad (đạt bí mật tuyệt đối).

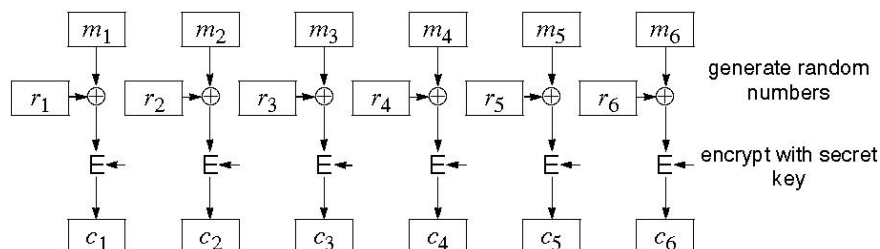


Hình 2.12. Sơ đồ chế độ mật mã CTR. Nguồn: [19]

CÂU HỎI VÀ BÀI TẬP

1. Confusion và diffusion là gì? Nguyên lý tạo ra chúng có khác nhau?
2. Cấu trúc sử dụng vòng lặp Feistel là gì? Tại sao lại cần nhiều vòng lặp? Sự thực hiện ở các vòng lặp có hoàn toàn giống nhau?
3. Tính đối hợp là gì? Tại sao lại cần tính đối hợp trong thiết kế DES?
4. Trong thuật toán DES, chứng minh tính đối hợp của T và F đồng thời chỉ rõ tại sao $x = \text{DES}(\text{DES}^{-1}(x))$ với mọi x là chuỗi nhị phân 64 bit.
5. Các khóa con của DES có hoàn toàn biệt lập (không thể suy ra lẫn nhau)?
6. Các S-Box có tính chất gì đặc biệt? Nếu không quan tâm đến việc đảm bảo các tính chất đặc biệt này mà chỉ cần đảm bảo nguyên tắc cấu trúc đã biết, người ta có thể tạo ra bao nhiêu S-Box khác nhau?
7. Hãy giải thích chiều dài khóa thực sự của 2-DES chỉ là 57. (Gợi ý: nếu biết trước vài cặp (bản rõ, bản mã) kẻ địch chỉ tốn khoảng 2^{57} lời gọi thực hiện DES hoặc DES^{-1} để tìm ra khóa).
8. Hãy vẽ sơ đồ giải mã cho chế độ CBC, CFB.
9. Hãy so sánh hai chế độ mật mã ECB và CTR.
10. Hãy so sánh hai dạng sơ đồ mật mã dưới đây, từ đó liên hệ giữa CBC với mật mã one-time-pad.

Sơ đồ A: Sử dụng một chuỗi ngẫu nhiên làm khóa chung



Sơ đồ B: Biểu diễn lại CBC

